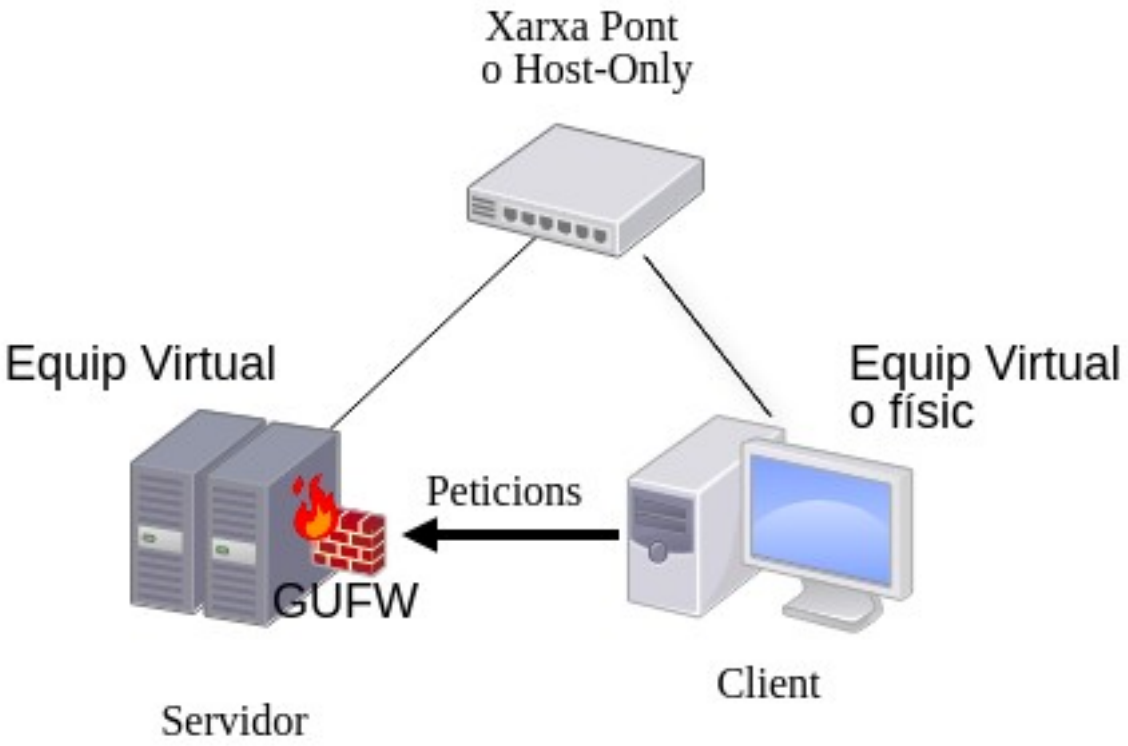
01.firewall-personal-corporatiu



Nom: Víctor Risco Ruiz
Professor: Pau Tomé
Assignatura: M 06
Any: 2025

Index

Reptes..... 4
1. TALLAFOCS AMB GUI PER UBUNTU.....4
1- Instal·la el programari Gufw en una màquina virtual Ubuntu Desktop (l'anomenarem "Servidor") i arrenca'l.....4
2-En una altre equip virtual Ubuntu (serà "Client") instal·la el programari nmap. Ens servirà per fer "escanneig" de ports i comprovar si es pot accedir als serveis del Server.....6
3- Instal·la Apache i openssh-server al "Server".....6
4- Comprova que pots veure els serveis actius al servidor des del "Client", accedint amb un navegador web i un client ssh.....6
5- Comprova que nmap, et mostra que els ports dels serveis web i sshd estan oberts (escoltant).....8
6- Activa ara el Firewall al "Server" i posa l'opció "Incoming" a "Deny" i "Outgoing" a "Allow" (opcions per defecte). Des del client comprova que els ports dels serveis ja no són accessibles i tampoc es pot accedir amb els clients web i ssh.....8
7- Al "Listening report" del Firewall tenim una llista dels serveis que estan funcionant. Si escollim apache2 i piquem el botó "+" podem afegir una regla que fa referència al port on escolta apache. Volem afegir una regla per permetre que les peticions arribin al servidor apache2.....10
8- Comprova que el servei ara està disponible amb nmap i el client web.....12
9- Fes el mateix amb el servei sshd (permetre'l), però amb l'opció per configuració ràpida d'aplicacions. pica el botó "+" del desplegable "Regles" (pestanya "preconfigurat"). Prova a afegir una regla per a permetre SSH (busca entre les categories).....13
10-Comprova des del client que el port de ssh ara és accessible i connecta des del client SSH. 14
FITA 1: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat..... 15
2. Configuració de Pfsense.....15
1- Creeu una nova màquina virtual per a instal·lar-hi el Pfsense. En les opcions de VirtualBox: 15
3- Si no s'ha fet correctament, haureu d'assignar les interfícies WAN i LAN respectivament al pfsense (opció 1)..... 16
4- Creeu una màquina virtual amb Ubuntu Desktop i poseu-li una interfície VBox interna a la mateixa xarxa interna que el Pfsense (serà la màquina de la xarxa local).....16
5- Ara podrem configurar via web de forma remota el pfsense. Segurament us apareixerà la primera vegada el Wizard o assistent de configuració inicial. Si no, podeu anar a "System->Setup Wizard"..... 19
6- Aneu a "System->General Setup" per a comprovar la configuració del pfsense.....21 21
7- Aneu a "Diagnostics->Ping":.....22
FITA 2: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat..... 23
3. Proves i configuració de política permissiva.....24
8- Si tot és correcte, ja tenim el nostre firewall corporatiu funcionant, però sense filtrar res.. 24
Política PERMISSIVA al Firewall: blocar el que no volem.....29
9- Apliquem la política oberta (tot permés, apliquem restriccions). Posarem restriccions de certs protocols. Bloca els ICMP de la xarxa LAN interna. Això es fa a "Firewall→Rules"….29

FITA 3: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.....36
4. Política RESTRICTIVA al Firewall, permetre el que volem.....37
10- Ara mirarem de blocar tot el tràfic de la xarxa interna cap a internet, per configurar una política restrictiva (tot tancat, obrim excepcions).....37
11- Obrirem l'accés de la xarxa interna cap a serveis web i web segura.....37
12-Obrirem l'accés a ssh. Recorda posar-la abans de la que bloca tots els protocols.....37
13- Comprova amb Wireshark, des de la màquina física quines IP's són les que realment fan la petició ssh.....38
FITA 4: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.....38

Reptes

1. TALLAFOCS AMB GUI PER UBUNTU

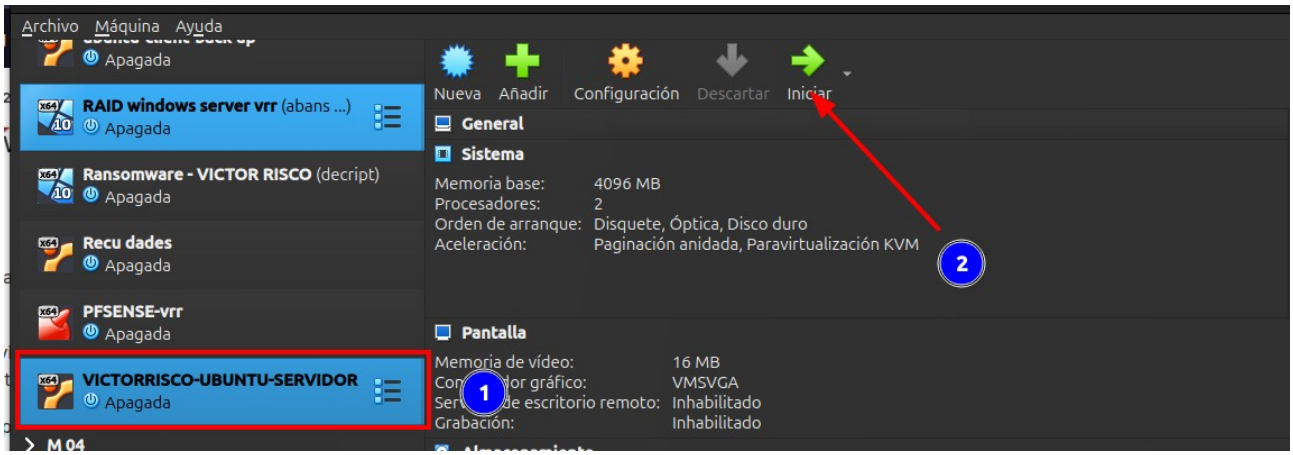
1- Instal·la el programari Gufw en una màquina virtual Ubuntu Desktop (l'anomenarem "Servidor") i arrenca'l.

HE CANVIADO LA CONTRASENYA I NO ES NI server NI P@ssw0rd

Jo he importat una ova per la màquina virtual Ubuntu Desktop i l'he posat aquest nom:



Quan s'hagi importat l'arrenquem



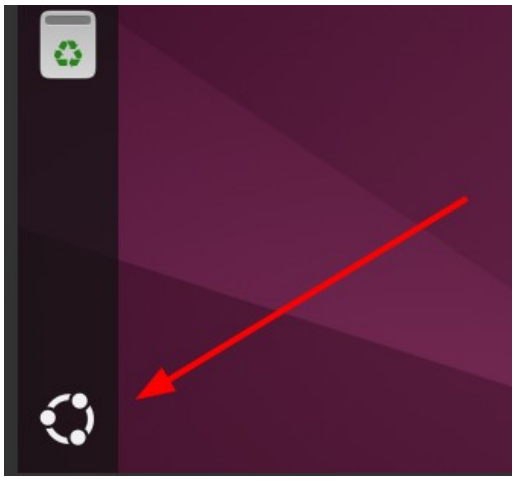
Fem un update i upgrade per fer actualitzacions.

```
usuari@server-victorrisco:~$ sudo apt update && sudo apt upgrade --fix-missing --fix-broken -y
```

I instal·lem el programari gufw

```
usuari@server-victorrisco:~$ sudo apt install gufw
```

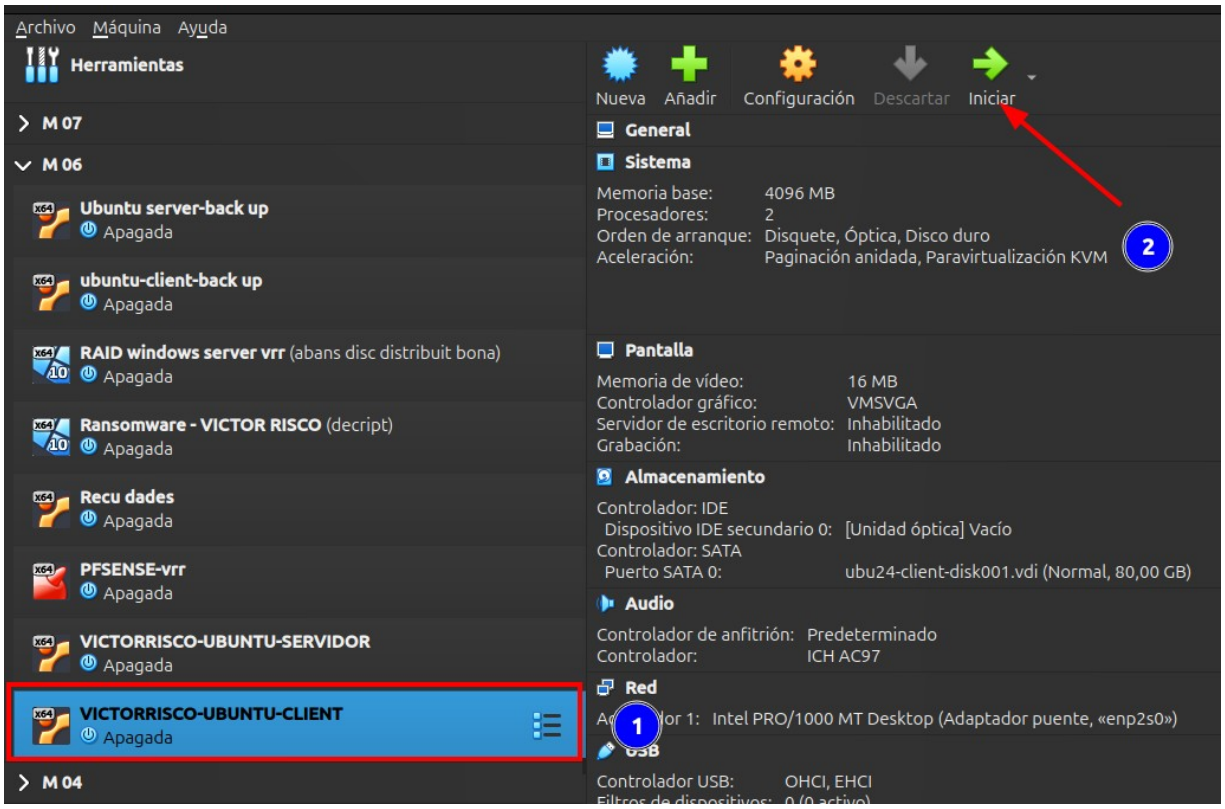
I se'ns haurà instal·lat el programari per mode gràfic i si anem a la rodona amb punts de a baix i després busquem gufw ens sortirà l'aplicació.




gufw
Configuració de…

2-En una altre equip virtual Ubuntu (serà "Client") instal·la el programari nmap. Ens servirà per fer "escanneig" de ports i comprovar si es pot accedir als serveis del Server.

Torno a importar la ova i li poso de nom “Client” i l’arrenco.



Ara instal·lem el programari nmap.

```
usuari@client-victorrisco:~$ sudo apt install nmap
```

3- Instal·la Apache i openssh-server al "Server".

Instal·lem el programari apache2 i el servei ssh.

```
usuari@server-victorrisco:~$ sudo apt install apache2 openssh-server
```

4- Comprova que pots veure els serveis actius al servidor des del "Client", accedint amb un navegador web i un client ssh.

```
usuari@client-victorrisco:~$ ssh usuari@172.16.26.196
usuari@172.16.26.196's password:
```

```
usuari@client-victorrisco:~$ ssh usuari@172.16.26.196
usuari@172.16.26.196's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-52-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

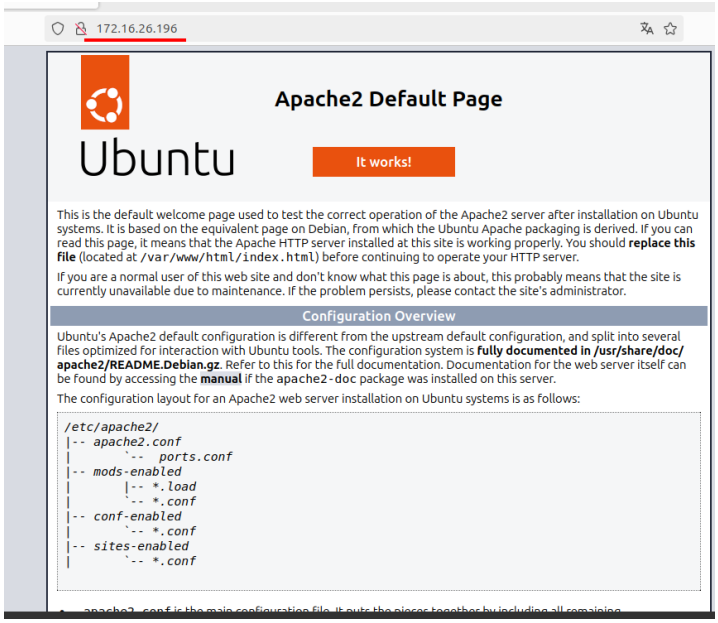
No està activat el mateniment expandit de seguretat per a Applications

Es poden aplicar immediatament 0 actualitzacions.

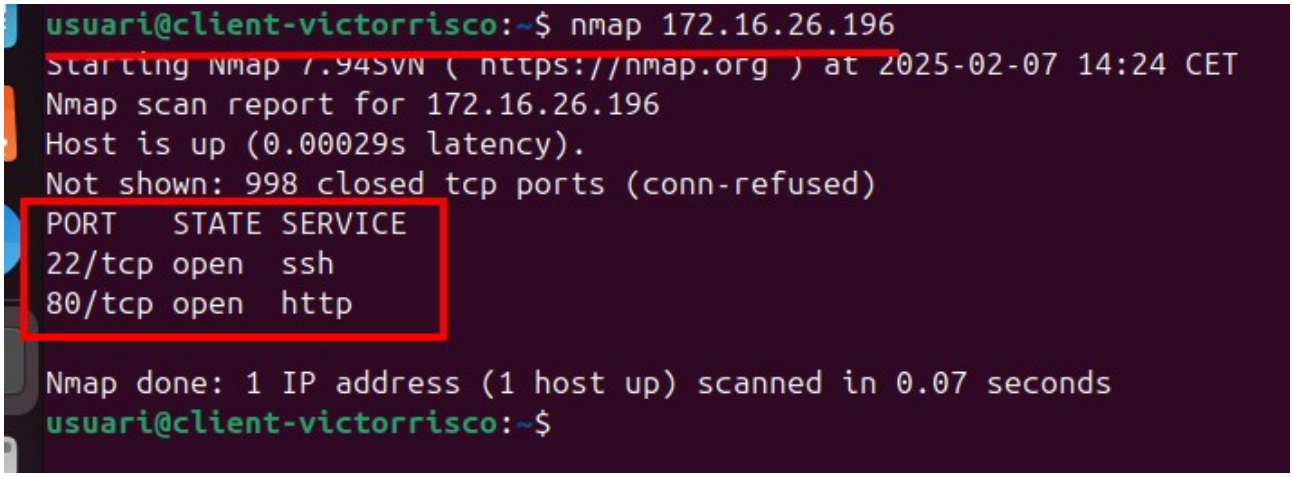
Activeu ESM Apps per rebre actualitzacions de seguretat addicionals en el
Vegeu https://ubuntu.com/esm o executeu: sudo pro status

Last login: Fri Feb  7 14:20:33 2025 from 172.16.26.154
usuari@server-victorrisco:~$
```

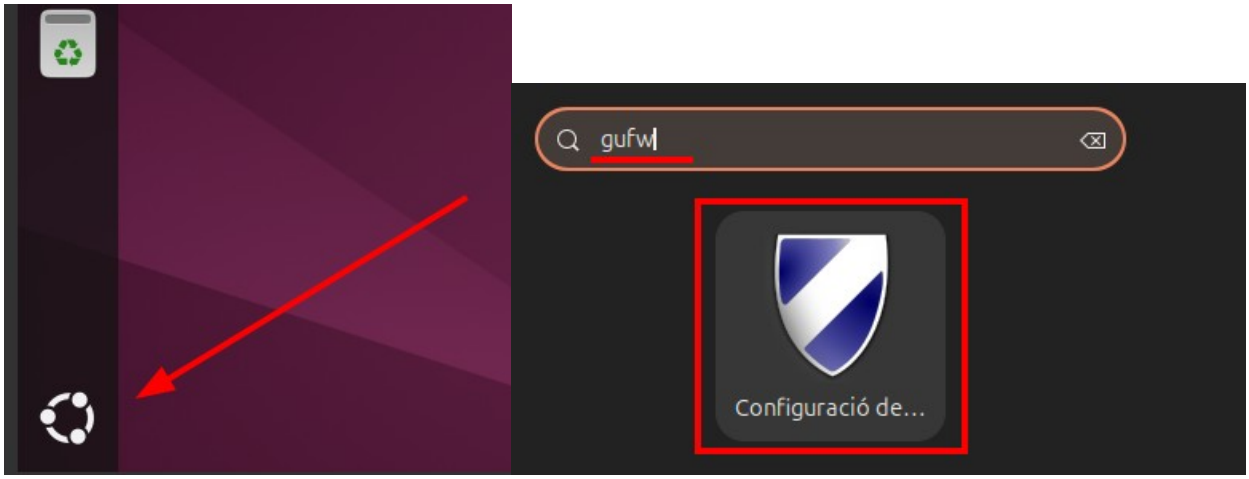


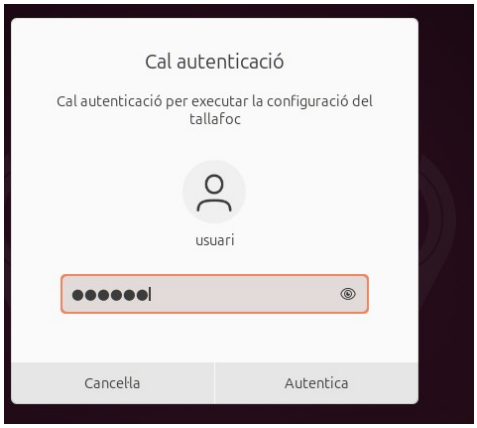


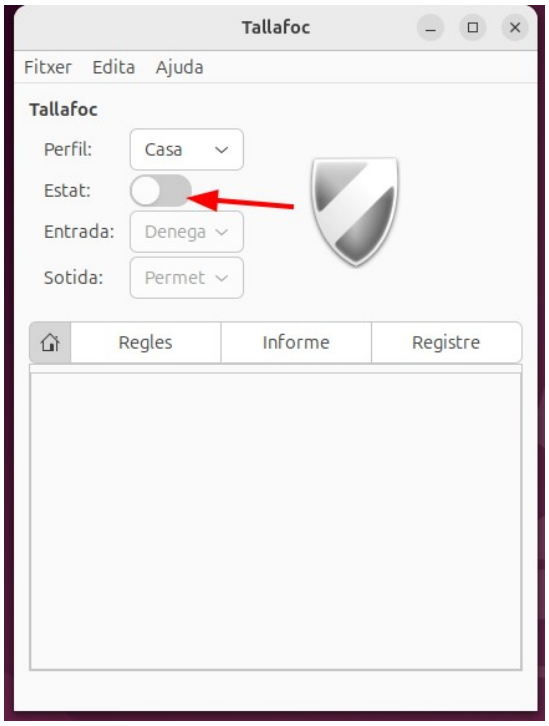
5- Comprova que nmap, et mostra que els ports dels serveis web i sshd estan oberts (escoltant).

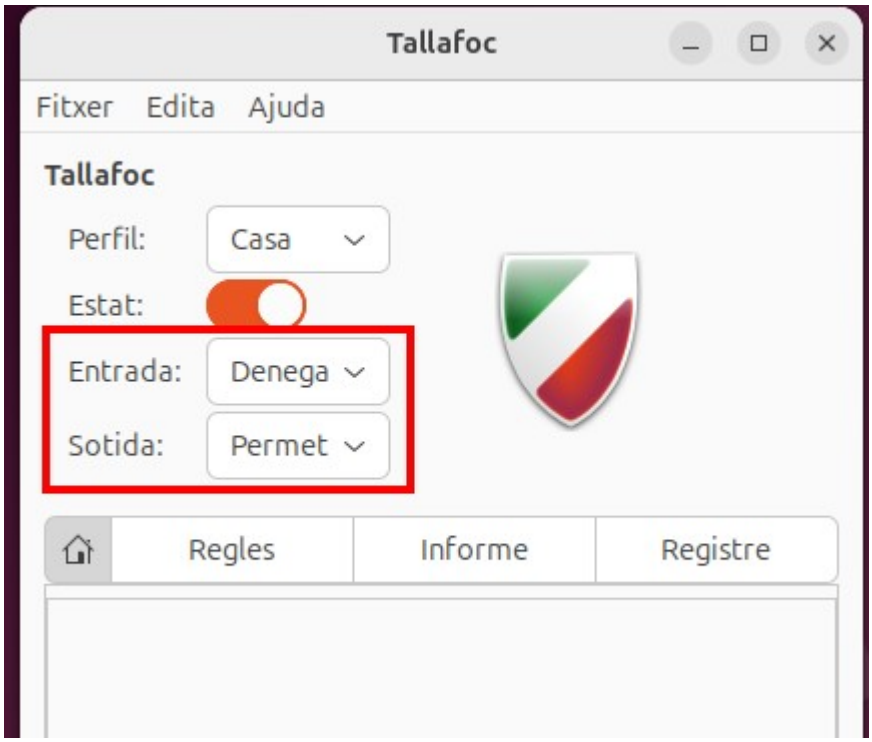


6- Activa ara el Firewall al "Server" i posa l'opció "Incoming" a "Deny" i "Outgoing" a "Allow" (opcions per defecte). Des del client comprova que els ports dels serveis ja no són accessibles i tampoc es pot accedir amb els clients web i ssh.

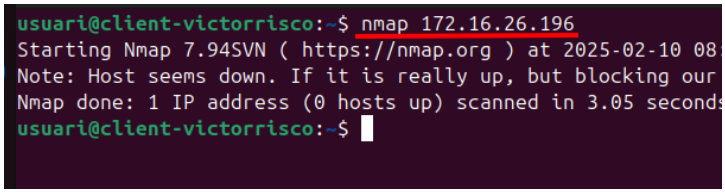








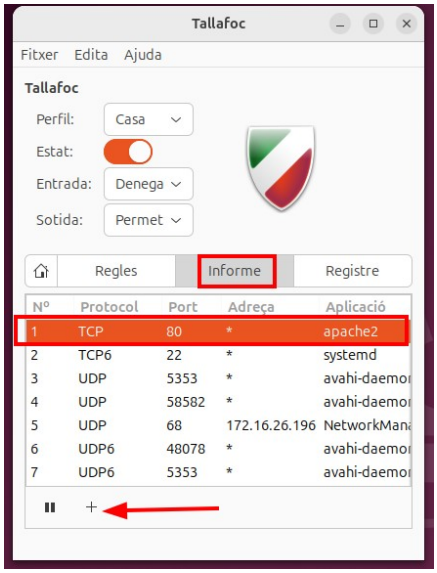
COMPROVACIO CLIENT

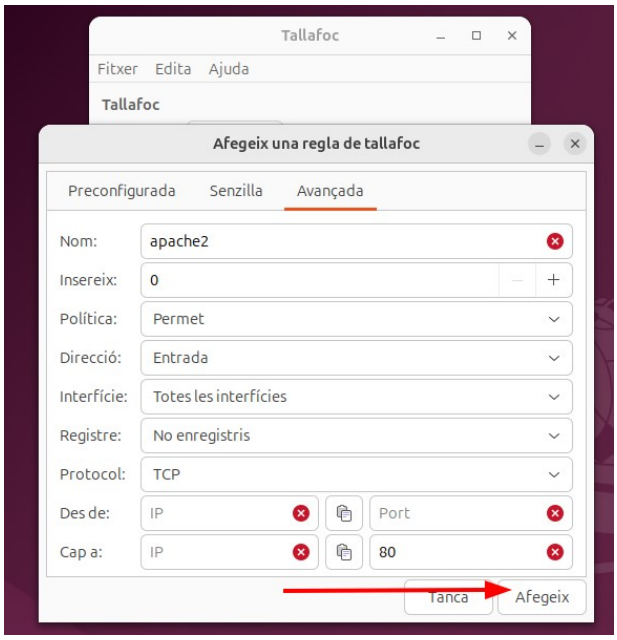


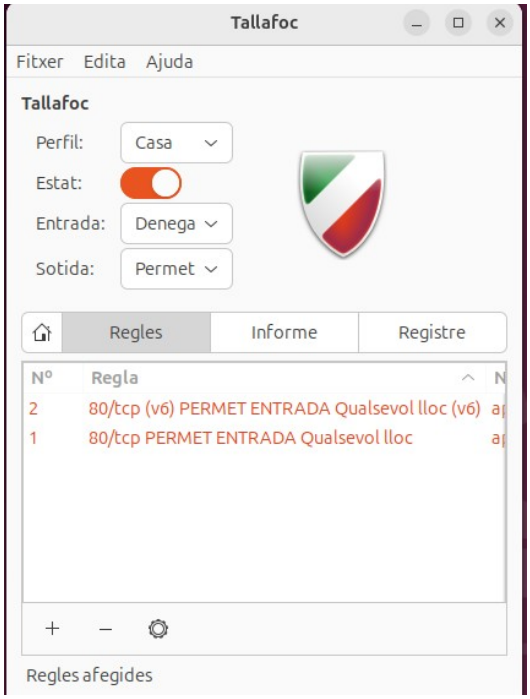
```
usuari@client-victorrisco:~$ ssh usuari@172.16.26.196
```



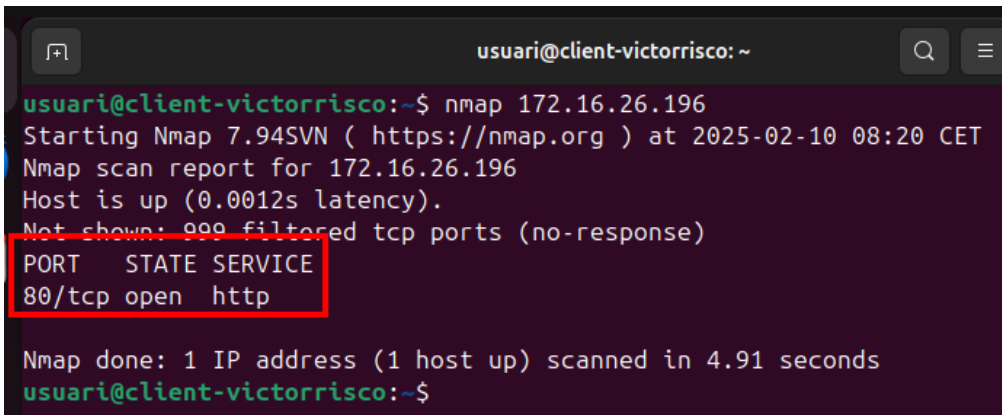
7- Al "Listening report" del Firewall tenim una llista dels serveis que estan funcionant. Si escollim apache2 i piquem el botó "+" podem afegir una regla que fa referència al port on escolta apache. Volem afegir una regla per permetre que les peticions arribin al servidor apache2.

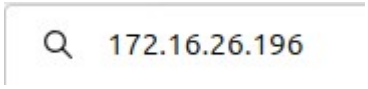


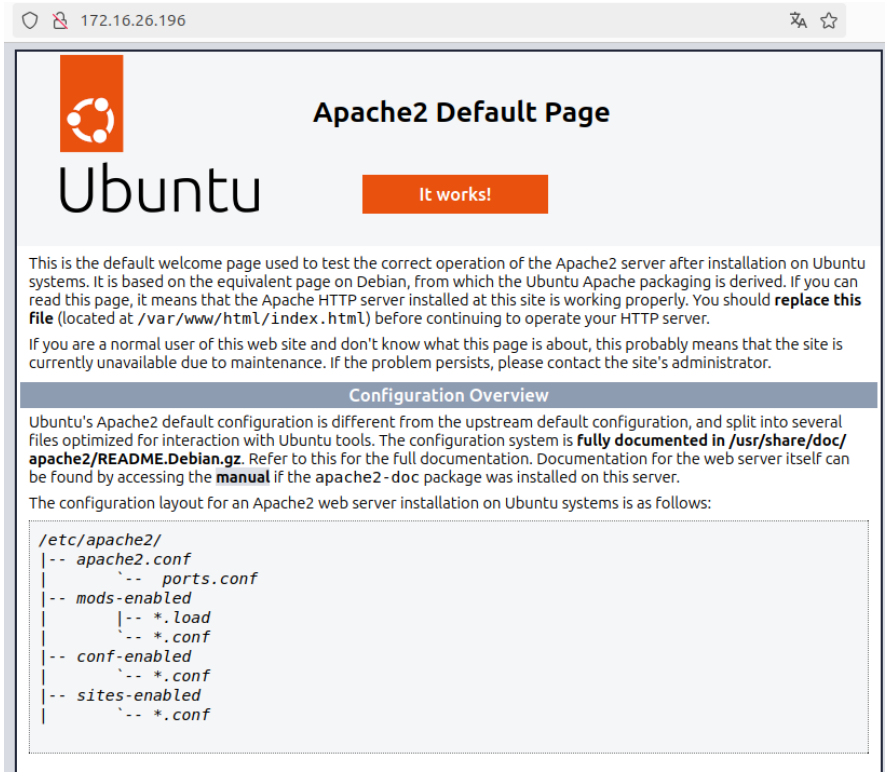

Tallafoc
Fitxer Edita Ajuda
Tallafoc
Afegeix una regla de tallafoc
Preconfigurada Senzilla Avançada
Nom: apache2
Insereix: 0
Política: Permet
Direcció: Entrada
Interfície: Totes les interfícies
Registre: No enregistris
Protocol: TCP
Des de: IP Port
Cap a: IP 80
Tanca Afegeix


Tallafoc
Fitxer Edita Ajuda
Tallafoc
Perfil: Casa
Estat:
Entrada: Denega
Sotida: Permet
Regles Informe Registre
Nº Regla
2 80/tcp (v6) PERMET ENTRADA Qualsevol lloc (v6)
1 80/tcp PERMET ENTRADA Qualsevol lloc
Regles afegides

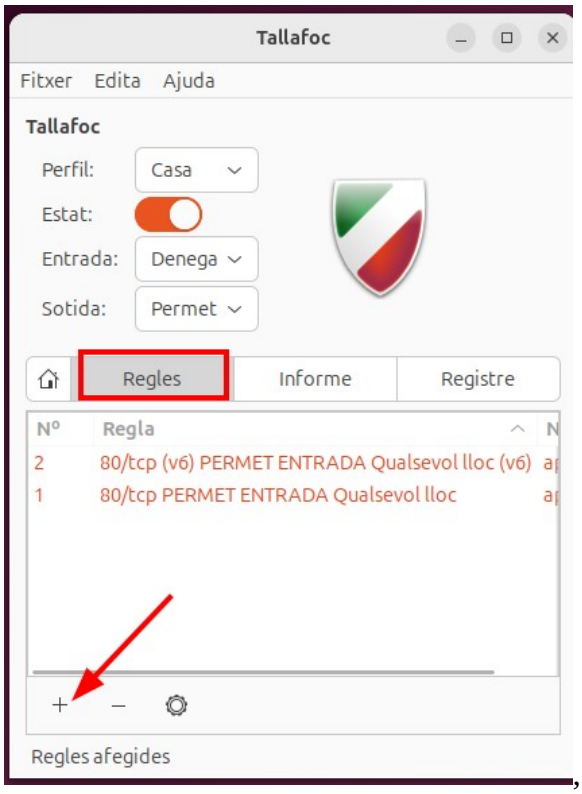
8- Comprova que el servei ara està disponible amb nmap i el client web.



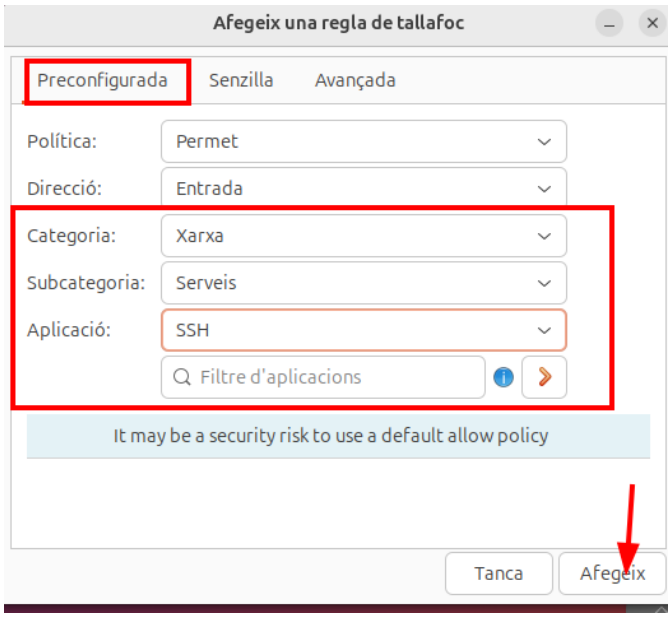


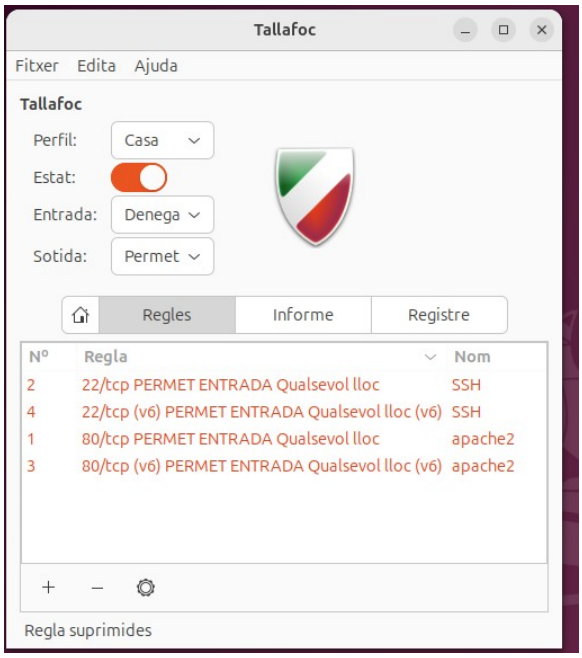


9- Fes el mateix amb el servei sshd (permetre'l), però amb l'opció per configuració ràpida d'aplicacions. pica el botó "+" del desplegable "Regles" (pestanya "preconfigurat"). Prova a afegir una regla per a permetre SSH (busca entre les categories).



,





10-Comprova des del client que el port de ssh ara és accessible i connecta des del client SSH.

```
usuari@client-victorrisco:~$ nmap 172.16.26.196
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-10 08:27 CE
Nmap scan report for 172.16.26.196
Host is up (0.00019s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 0.06 seconds
```

```
usuari@client-victorrisco:~$ ssh usuari@172.16.26.196
```

```
usuari@client-victorrisco:~$ ssh usuari@172.16.26.196
usuari@172.16.26.196's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-52-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

No està activat el mateniment expandit de seguretat per a Applications

Es poden aplicar immediatament 0 actualitzacions.

Activeu ESM Apps per rebre actualitzacions de seguretat addicionals en el futur
Vegeu https://ubuntu.com/esm o executeu: sudo pro status

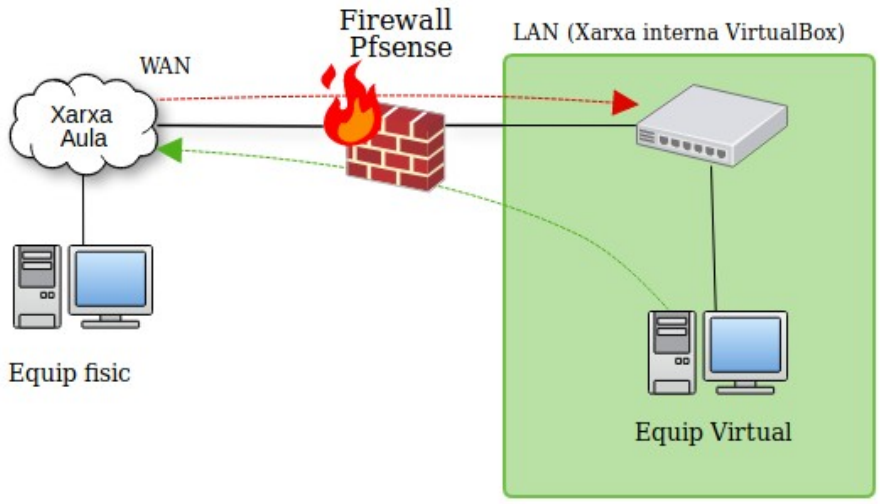
Last login: Fri Feb  7 14:22:20 2025 from 172.16.26.154
usuari@server-victorrisco:~$
```

FITA 1: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.

PARA UTILIZAR EL FTP INSTALAMOS EL PAQUETE vsftpd AL SERVIDOR

2. Configuració de Pfsense

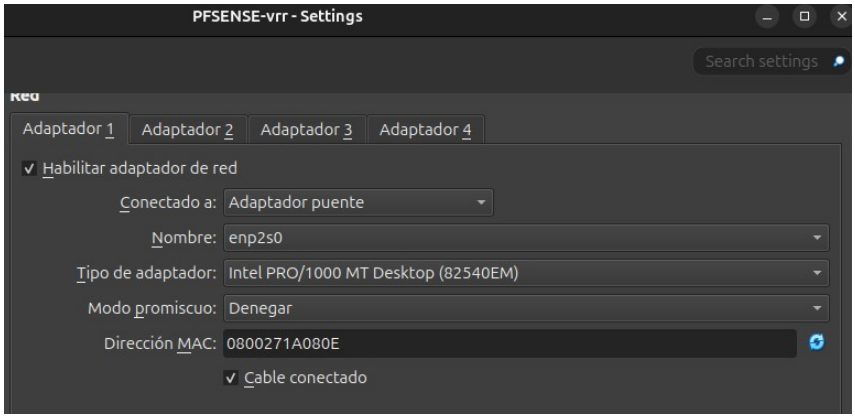
Farem servir dos equips virtuals: un amb Pfsense i un altre amb Ubuntu Desktop (pot ser la màquina creada a l'apartat anterior). També farem servir l'equip físic.



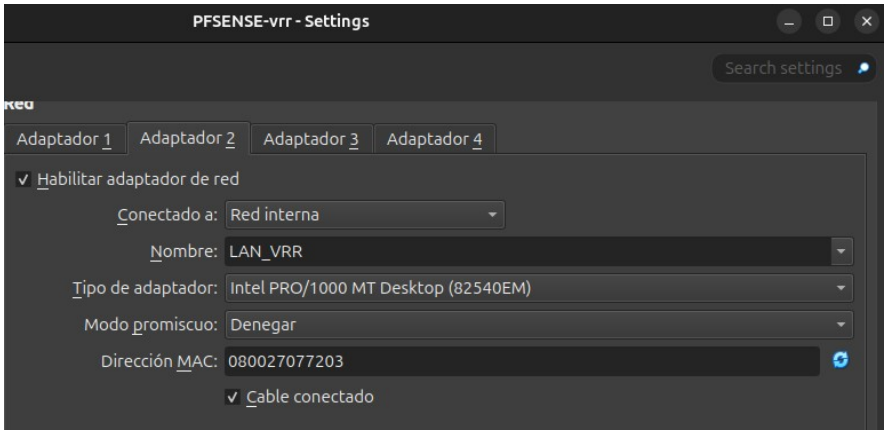
1- Creeu una nova màquina virtual per a instal·lar-hi el Pfsense. En les opcions de VirtualBox:



Activeu una interfície pont (xarxa WAN o externa pel firewall)



Activeu una interfície interna (xarxa LAN o interna pel Pfsense).



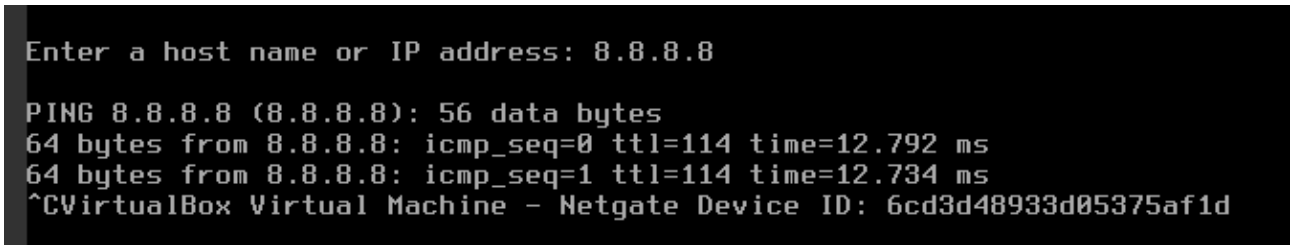
Ara Instal·leu la distribució Pfsense (mode fàcil).

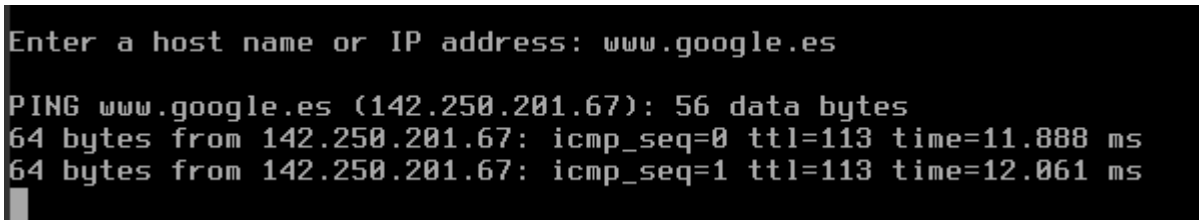
JA HO HE FET EN UN DOCUMENT APART.

3- Si no s'ha fet correctament, haureu d'assignar les interfícies WAN i LAN respectivament al pfsense (opció 1).

Pfsense anomena les interfícies em0 i em1. Poseu WAN a la primera (és la interfície pont cap a internet) i poseu em1 a la segona (xarxa LAN interna).

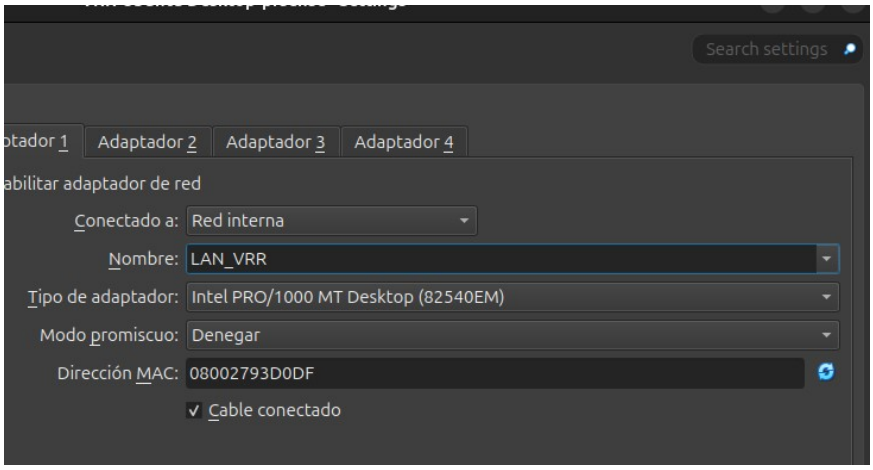
Comproveu fent ping desde la consola del pfsense (opció 7 o opció 8 escrivint ping...) que veieu per exemple el host 8.8.8.8 i www.google.es. Ja tindrem internet.



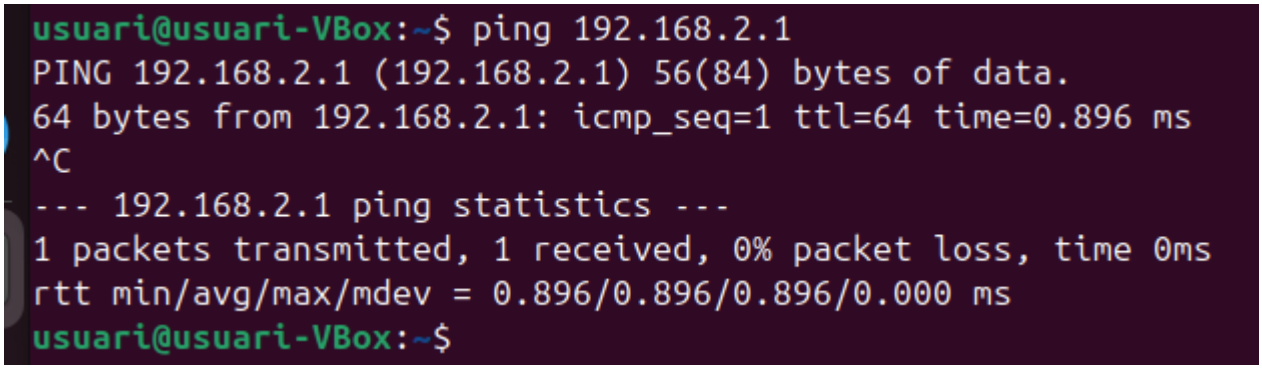


4- Creeu una màquina virtual amb Ubuntu Desktop i poseu-li una interfície VBox interna a la mateixa xarxa interna que el Pfsense (serà la màquina de la xarxa local).

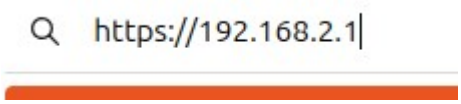




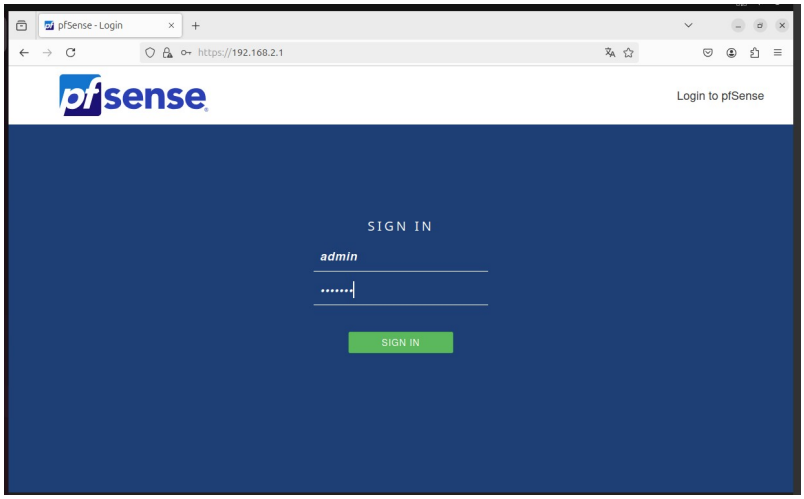
Comproveu que podeu fer ping a la IP interna del PfSense.



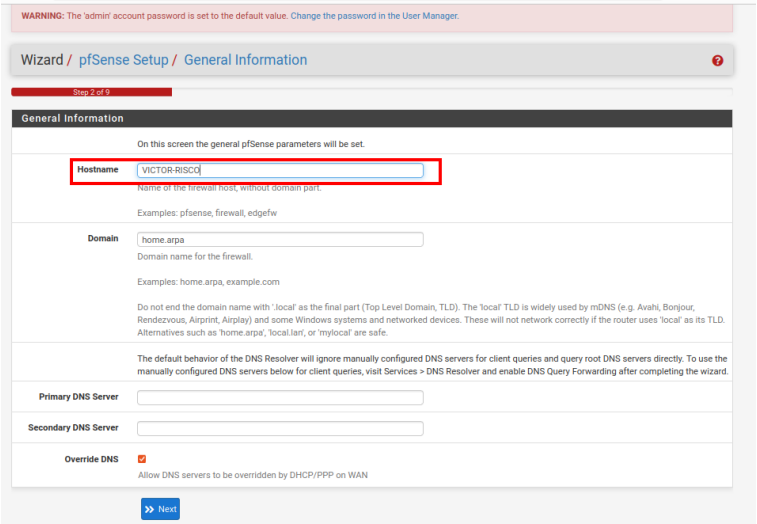
Obriu el navegador i escriviu https://ip-interna-pfsense.

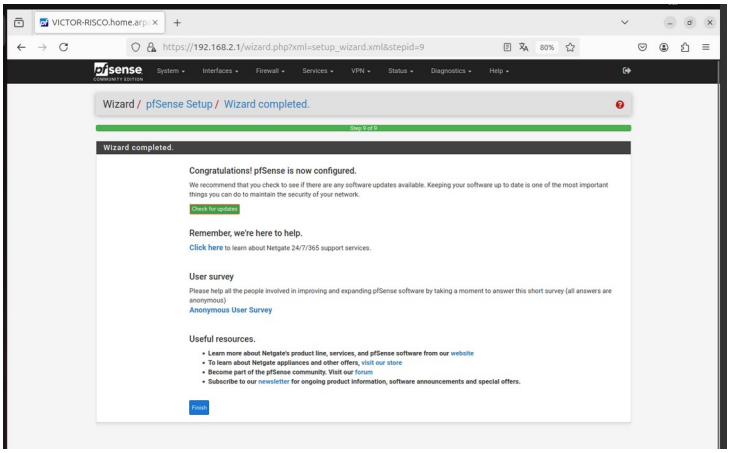


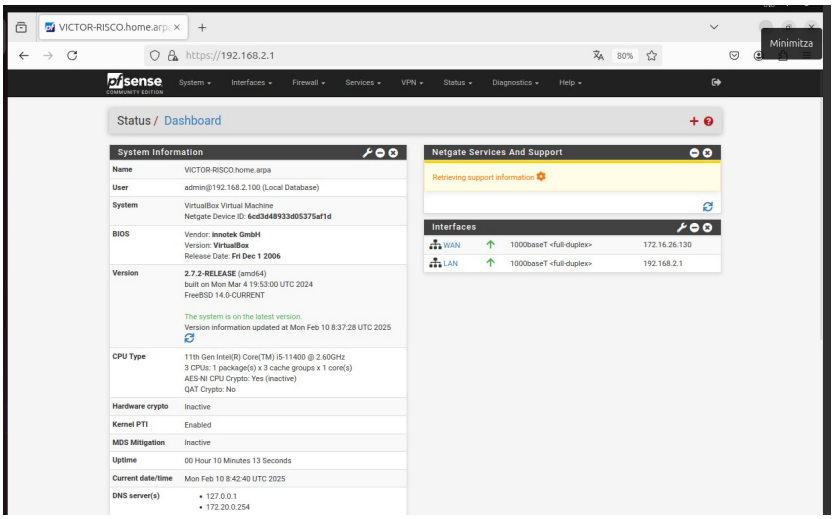
Així veurem la configuració via web del pfsense. El nom d'usuari per defecte és admin i password pfsense.



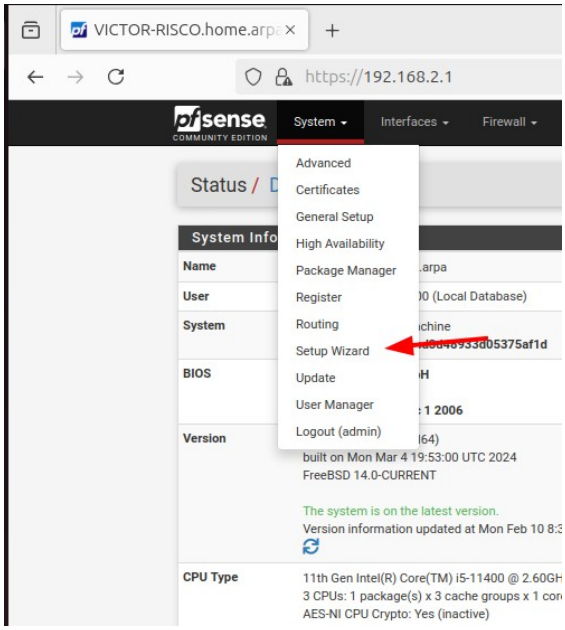
Configureu com a nom de host el vostre NOM-COGNOM.


WARNING: The 'admin' account password is set to the default value. Change the password in the User Manager.
Wizard / pfSense Setup / General Information
Step 2 of 9
General Information
On this screen the general pfSense parameters will be set.
Hostname
VICTOR-RISCO
Name of the firewall host, without domain part.
Examples: pfsense, firewall, edgefw
Domain
home.arpa
Domain name for the firewall.
Examples: home.arpa, example.com
Do not end the domain name with '.local' as the final part (Top Level Domain, TLD). The 'local' TLD is widely used by mDNS (e.g. Avahi, Bonjour, Rendezvous, Airprint, Airplay) and some Windows systems and networked devices. These will not network correctly if the router uses 'local' as its TLD. Alternatives such as 'home.arpa', 'local.lan', or 'mylocal' are safe.
The default behavior of the DNS Resolver will ignore manually configured DNS servers for client queries and query root DNS servers directly. To use the manually configured DNS servers below for client queries, visit Services > DNS Resolver and enable DNS Query Forwarding after completing the wizard.
Primary DNS Server
Secondary DNS Server
Override DNS
Allow DNS servers to be overridden by DHCP/PPP on WAN
Next


VICTOR-RISCO.home.arpa
https://192.168.2.1/wizard.php?xml=setup_wizard.xml&stepid=9
Wizard / pfSense Setup / Wizard completed.
Step 9 of 9
Wizard completed.
Congratulations! pfSense is now configured.
We recommend that you check to see if there are any software updates available. Keeping your software up to date is one of the most important things you can do to maintain the security of your network.
Check for updates
Remember, we're here to help.
Click here to learn about Netgate 24/7/365 support services.
User survey
Please help all the people involved in improving and expanding pfSense software by taking a moment to answer this short survey (all answers are anonymous)
Anonymous User Survey
Useful resources.
Learn more about Netgate's product line, services, and pfSense software from our website
To learn about Netgate appliances and other offers, visit our store
Become part of the pfSense community. Visit our forum
Subscribe to our newsletter for ongoing product information, software announcements and special offers.
Finish

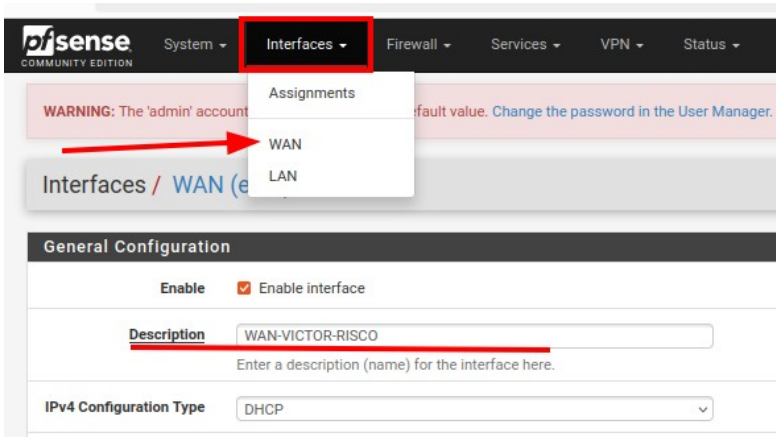

VICTOR-RISCO.home.arpa
https://192.168.2.1
Minimitza
Status / Dashboard
System Information
Name
VICTOR-RISCO.home.arpa
User
admin@192.168.2.100 (Local Database)
System
VirtualBox Virtual Machine
Netgate Device ID: 6cd3d48933d05375af1d
BIOS
Vendor: Innotek GmbH
Version: VirtualBox
Release Date: Fri Dec 1 2006
Version
2.7.2-RELEASE (amd64)
built on Mon Mar 4 19:53:00 UTC 2024
FreeBSD 14.0-CURRENT
The system is on the latest version.
Version information updated at Mon Feb 10 8:37:28 UTC 2025
CPU Type
11th Gen Intel(R) Core(TM) i5-11400 @ 2.60GHz
3 CPUs: 1 package(s) x 3 cache groups x 1 core(s)
AES-NI CPU Crypto: Yes (inactive)
QAT Crypto: No
Hardware crypto
Inactive
Kernel PTI
Enabled
MDS Mitigation
Inactive
Uptime
00 Hour 10 Minutes 13 Seconds
Current date/time
Mon Feb 10 8:42:40 UTC 2025
DNS server(s)
127.0.0.1
172.20.0.254
Netgate Services And Support
Retrieving support information
Interfaces
WAN
1000baseT <full-duplex>
172.16.26.130
LAN
1000baseT <full-duplex>
192.168.2.1

5- Ara podrem configurar via web de forma remota el pfsense. Segurament us apareixerà la primera vegada el Wizard o assistent de configuració inicial. Si no, podeu anar a "System->Setup Wizard".

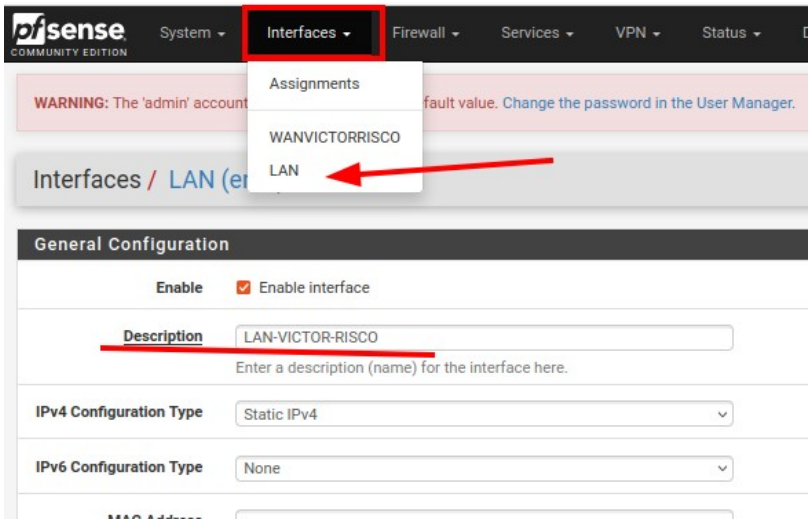


ATENCIÓ:

- Aneu al menú interfaces i **canvieu el nom de les interfícies WAN i LAN a WAN-NOM-COGNOM i LAN-NOM-COGNOM**

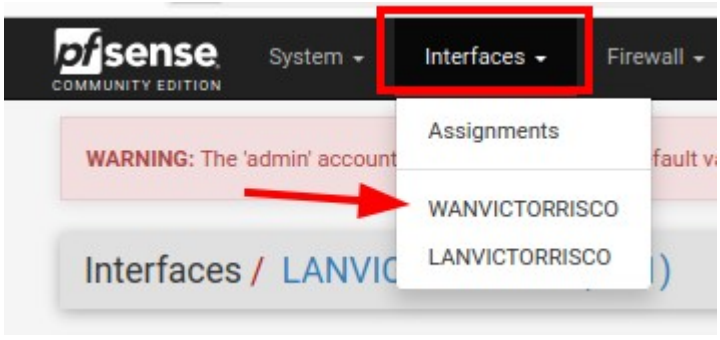


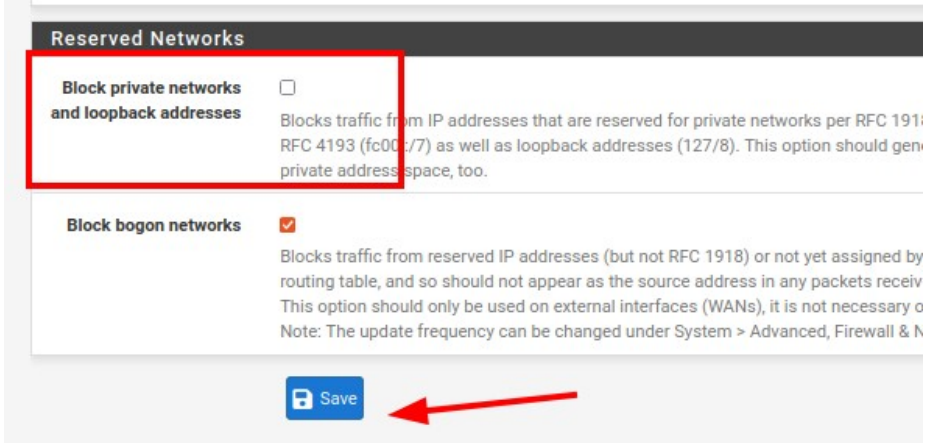
I li donem al boto desa.



I li donem al boto desa.

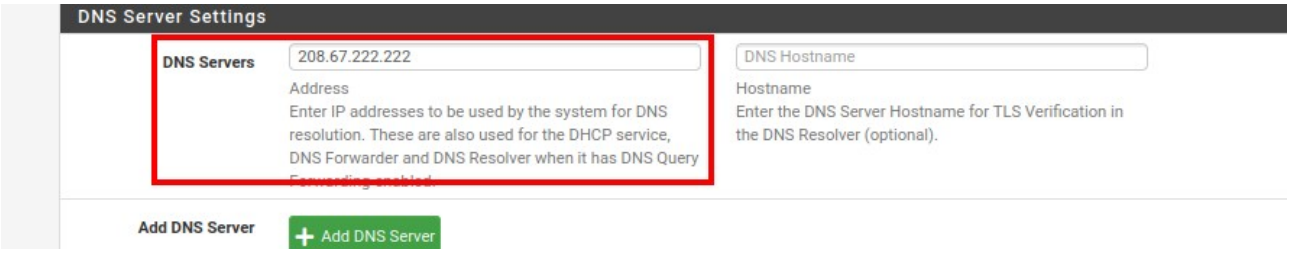
- Aneu al menú interfaces->WAN i a la secció "Reserved Networs" desactiveu el checkbox "block private networks". Així podreu accedir a la interfície WAN des del vostres equips físics (si no, el firewall ignora qualsevol paquet provinent d'una xarxa privada cap a la interfície WAN).



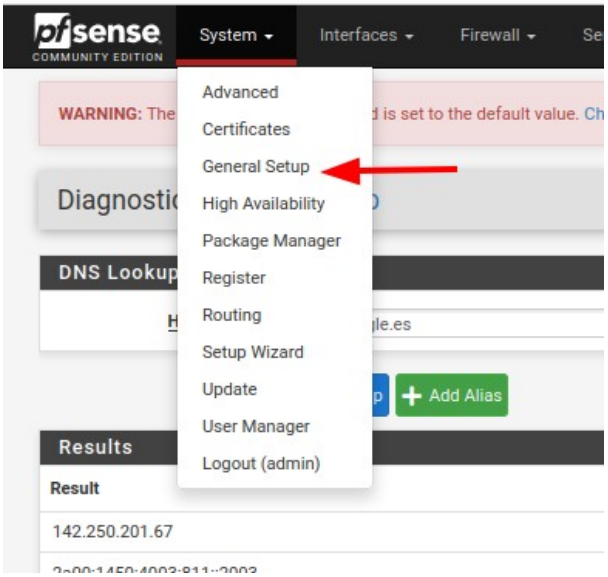


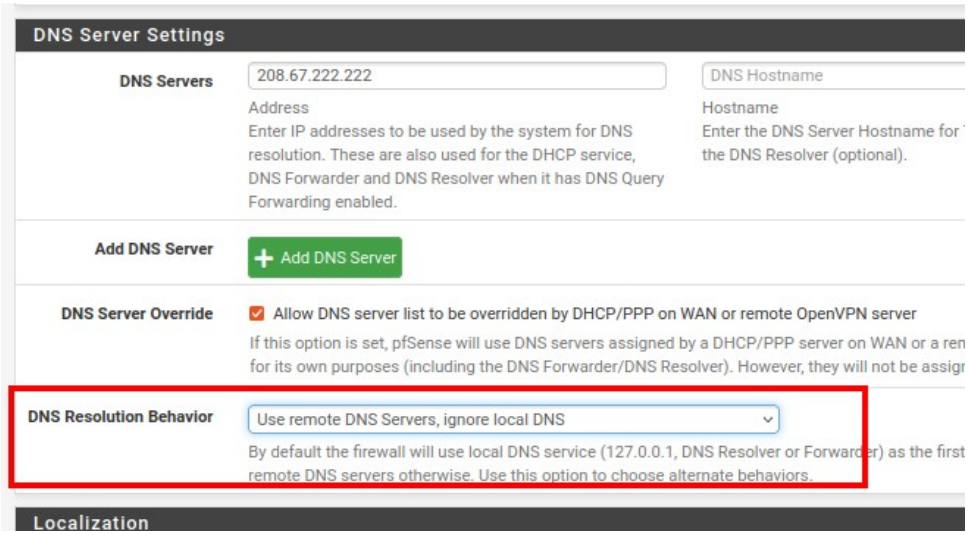
6- Aneu a "System->General Setup" per a comprovar la configuració del pfsense.

Assegureu-vos que la resolució de noms DNS es fa cap a un servidor DNS extern.

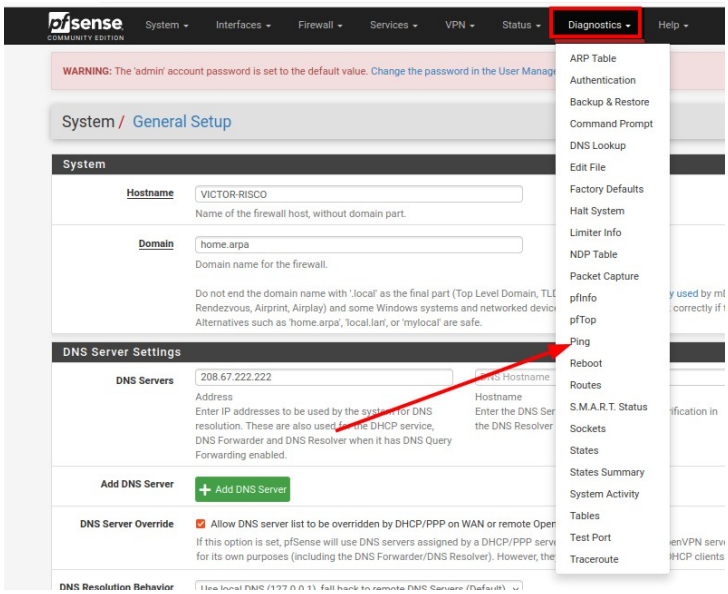


Si s'escull alguna opció de resoldre amb servidor DNS local, anirà tot més lent per que el pfsense no te activat un servidor DNS propi.

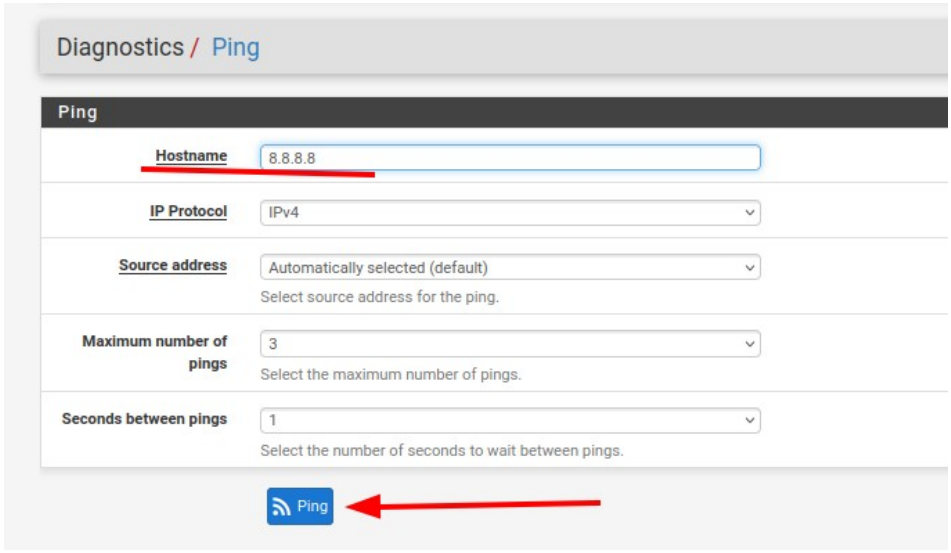


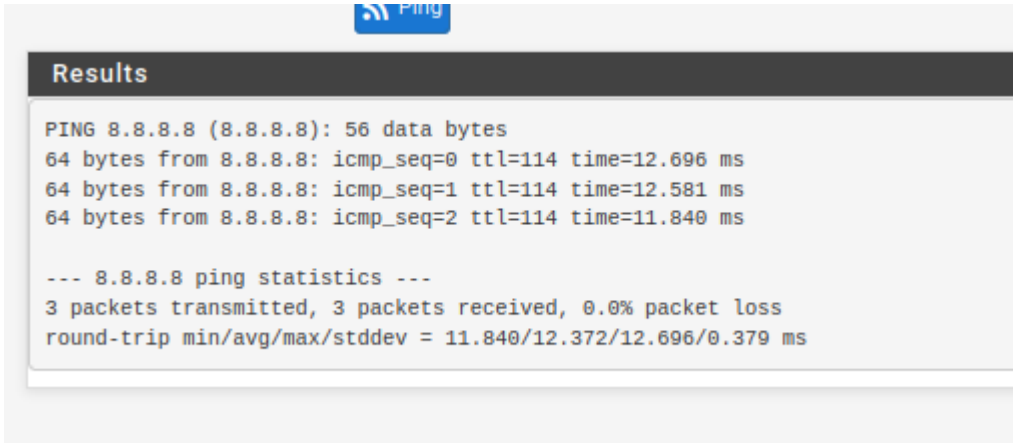


7- Aneu a "Diagnostics->Ping":

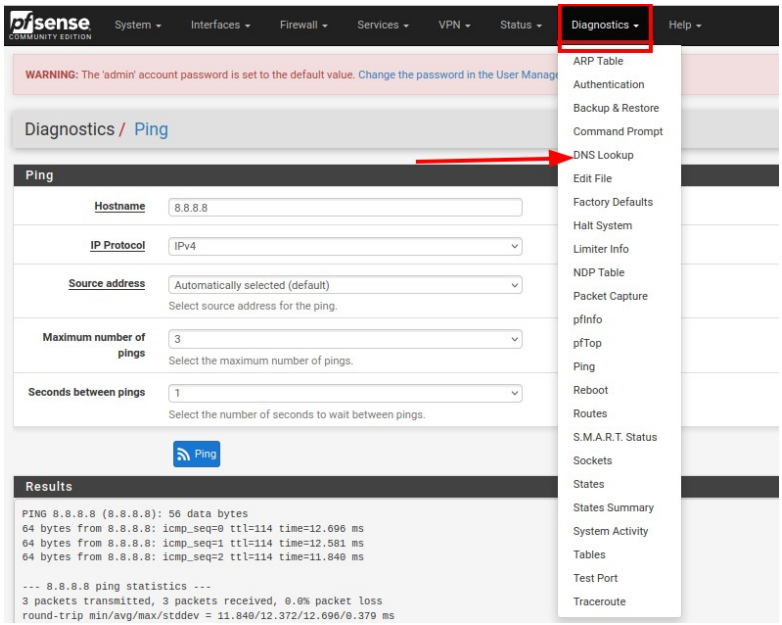


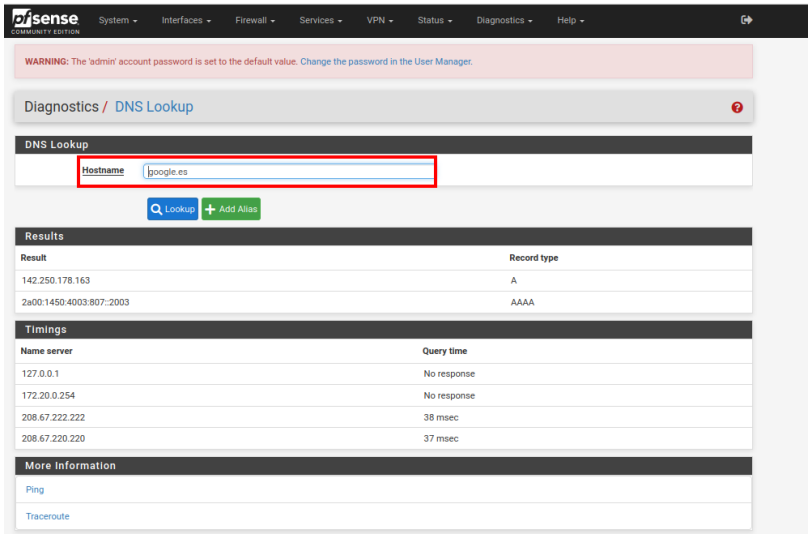
Proveu a fer ping a 8.8.8.8 (comprovació de que funciona l'enrutament).





Després "Diagnostics->DNS Lookup" i prova google.es (comprovació de que funciona la resolució DNS).





Així ens assegurem que el pfsense te internet (des de la consola web).

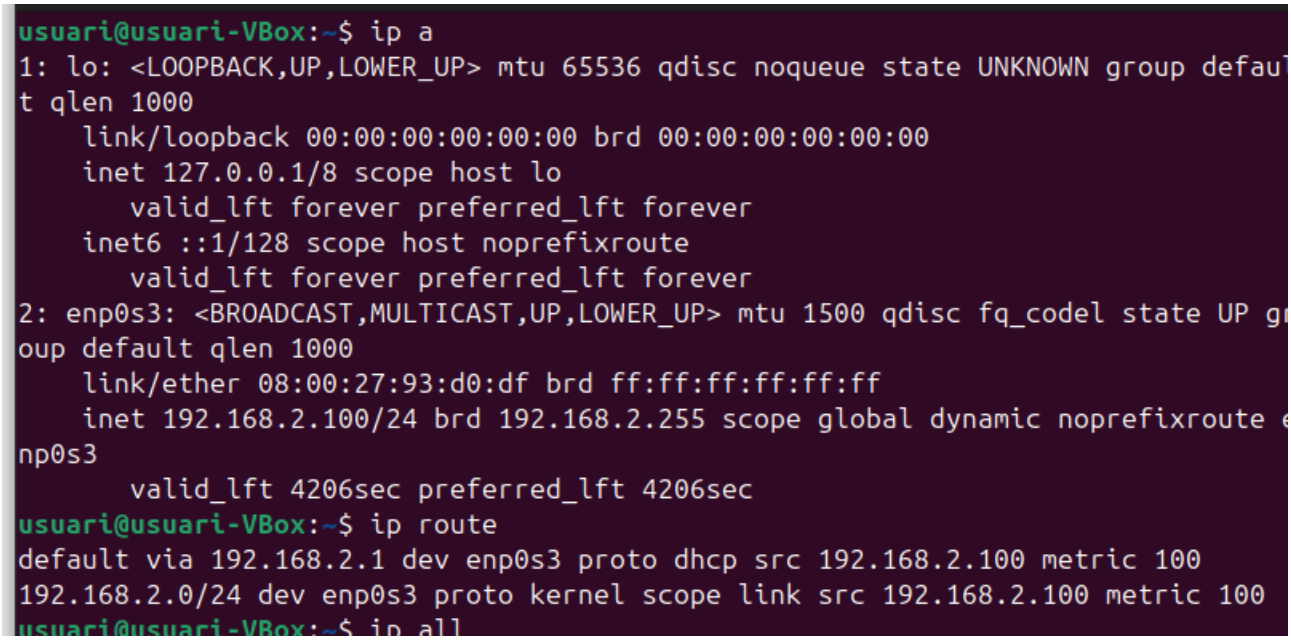
FITA 2: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.

3. Proves i configuració de política permissiva

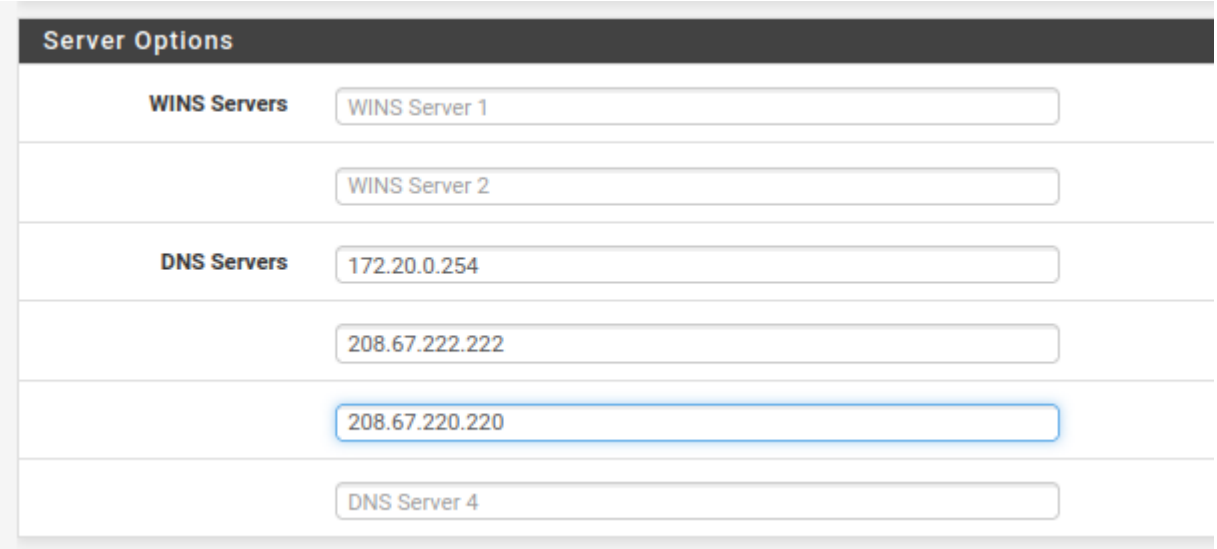
8- Si tot és correcte, ja tenim el nostre firewall corporatiu funcionant, però sense filtrar res.

El client es configura per DHCP ja que Pfsense activa per defecte el servei DHCP per la interfície LAN (si no ho ha fet, activa'l).

Comprova des del client la configuració IP (adreça, màscara, gateway i DNS) i que pots accedir a alguna web.



NOTA: Si la màquina client no resol noms DNS, podeu canviar la configuració del servidor DHCP del (Pfsense Services->DHCP Server->Pestanya LAN). El paràmetre de servidor DNS que dona als clients DHCP es pot configurar per exemple a 172.20.0.254 208.67.222.222 208.67.220.220 que són servidors DNS públics.



Comprova que el paràmetre Gateway per defecte conté l'adreça interna del Pfsense.

```
usuari@usuari-VBox:~$ ip route
default via 192.168.2.1 dev enp0s3 proto dhcp src 192.168.2.100 metric 100
```

Prova a connectar a ftp.rediris.es mitjançant la consola amb el client ftp (usuari "anonymous"). Comprova que s'hi pot accedir, escriu la comanda "passive" per activar el mode passiu del client FTP i que pots baixar algun fitxer amb la comanda get.

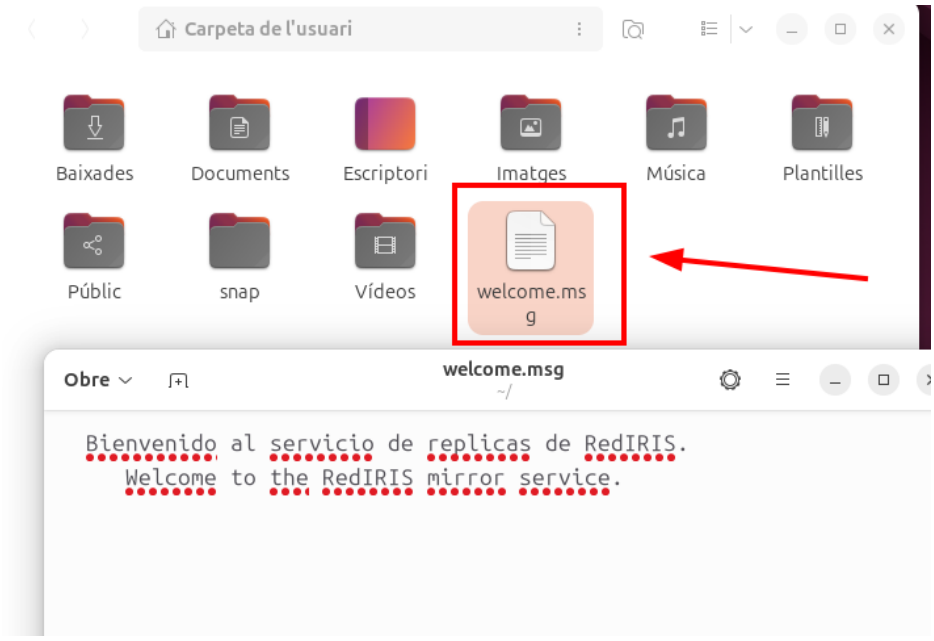
```
usuari@usuari-VBox:~$ sudo apt install vsftpd
```

```
usuari@usuari-VBox:~$ ftp ftp.rediris.es
```

```
usuari@usuari-VBox:~$ ftp ftp.rediris.es
Trying 130.206.13.2:21 ...
Connected to ftp.rediris.es.
220-  Bienvenido al servicio de replicas de RedIRIS.
220-     Welcome to the RedIRIS mirror service.
220 Only anonymous FTP is allowed here
Name (ftp.rediris.es:usuari): anonymous
```

```
usuari@usuari-VBox:~$ ftp ftp.rediris.es
Trying 130.206.13.2:21 ...
Connected to ftp.rediris.es.
220-  Bienvenido al servicio de replicas de RedIRIS.
220-     Welcome to the RedIRIS mirror service.
220 Only anonymous FTP is allowed here
Name (ftp.rediris.es:usuari): anonymous
230-            RedIRIS - Red Académica y de Investigación Española
230-                RedIRIS - Spanish National Research Network
230-
230-           ftp://ftp.rediris.es  -=-  http://ftp.rediris.es
230 Anonymous user logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> passive
```

```
..              debian-cd       sites
ftp> get welcome.msg
local: welcome.msg remote: welcome.msg
229 Extended Passive Mode Entered (|||48114|)
150 Accepted data connection
100% |***********************************|    93      571.19 KiB/s    00:00 ETA
226-File successfully transferred
226 0.000 seconds (measured here), 1.74 Mbytes per second
93 bytes received in 00:00 (138.44 KiB/s)
ftp>
```



Prova el servei SSH https://www.thc.org/segfault/ que ofereix un servidor ssh a Internet, on seràs root. Mira com cal connectar i comprova que funciona.

```
usuari@usuari-VBox:~$ ssh root@segfault.net
```

```
usuari@usuari-VBox:~$ ssh root@segfault.net
🦋 This is a Free SERVICE for researchers, developers and unix enthusiasts 👍
root@segfault.net's password:
######################################################################
#### DISCLAIMER: TO BE USED FOR CREATIVE AND GOOD PURPOSES ONLY.. ####
#### TO TINKER AND TO EXPLORE.     >>>USE AT YOUR OWN RISK<<<     ####
######################################################################


❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️
This server is not for Bug Bounty Hunters. It's for research
and testing things. Bug Bounty means that you make money and we pay
for the resources. That does not work for us.

Rule of thumb: If you are the main beneficiary of your work then
we kindly ask you to not use our free service.

Lots of LOVE from the fine SYSCOPS @ SEGFAULT.
❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️

Press ENTER to continue...
```

```
Lots of LOVE from the fine SYSCOPS @ SEGFAULT.
❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️❤️

Press ENTER to continue...

----------------------------------------------------------------------
You are using the FREE TIER without TOKEN. Various restrictions
apply:

- You have to wait 60 seconds ❤️
- Your network traffic is metered and at snail speed 🙈
- Your CPU power and memory are limited 🙉
- Your server is subject to automated ban 🙊
- Your server will shut down on log out 💩

Read 👉 https://thc.org/sf/token 👈 to remove these restrictions. ❤️

After login, see your restrictions by typing: cat /config/self/limits
----------------------------------------------------------------------
Read https://thc.org/sf/faq as well. 📖
----------------------------------------------------------------------

Continuing in 58 sec...
```

```
--> scp  updatesalute:stuff.tar.gz ~/
--> sshfs -o reconnect updatesalute:/sec ~/sec
----------------------------------------------------------------------
Token              : No See https://thc.org/segfault/token
Your workstation   : 81.33.29.20     (Cardedeu/Spain)
Reverse Port       : Type curl sf/port for reverse port.
Exit CryptoStorm   : 128.127.104.138 (Sweden)
Exit Mullvad       : 146.70.197.189  (Copenhagen/Denmark)
TOR Proxy          : 172.20.0.111:9050
Shared storage     : /everyone/UpdateSalute     (encrypted)
Your storage       : /sec                       (encrypted)
Your Onion WWW     : /onion                     (encrypted)
Your Web Page      : http://2xyr7jug4b5uhndzelsf7vgrxygttutc6h5mqzpwp7y6blk6owhxl
igd.onion/updatesalute/
SSH                : ssh -o "SetEnv SECRET=DwCkedVePOzHAkAbBAiIfOuU" root@adm.seg
fault.net
SSH (TOR)          : torsocks ssh -o "SetEnv SECRET=DwCkedVePOzHAkAbBAiIfOuU" roo
t@w5wc42fbltkdxpycsurj4zwxouhb3es3t2334lyte6euewrebjx4ryid.onion
SSH (gsocket)      : gsocket -s NGExNzFhNMYm ssh -o "SetEnv SECRET=DwCkedVePOzHAk
AbBAiIfOuU" root@adm.segfault.gsocket
SECRET             : DwCkedVePOzHAkAbBAiIfOuU <<<  WRITE THIS DOWN  <<<
┌──(root💀adm-UpdateSalute)-[~]
└─#
```

Prova el servei bandit.labs.overthewire.org, al port 2220. El nom d'usuari és "bandit0" i el password és bandit0.

```
usuari@usuari-VBox:~$ ssh -p 2220 bandit0@bandit.labs.overthewire.org
```

```
usuari@usuari-VBox:~$ ssh -p 2220 bandit0@bandit.labs.overthewire.org
The authenticity of host '[bandit.labs.overthewire.org]:2220 ([16.16.163.126]:22
20)' can't be established.
ED25519 key fingerprint is SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[bandit.labs.overthewire.org]:2220' (ED25519) to the
 list of known hosts.
                         _                     _ _ _
                        | |__   __ _ _ __   __| (_) |_
                        | '_ \ / _` | '_ \ / _` | | __|
                        | |_) | (_| | | | | (_| | | |_
                        |_.__/ \__,_|_| |_|\__,_|_|\__|


                      This is an OverTheWire game server.
            More information on http://www.overthewire.org/wargames

bandit0@bandit.labs.overthewire.org's password:
```

```
  Finally, network-access is limited for most levels by a local
  firewall.

--[ Tools ]--

 For your convenience we have installed a few useful tools which you can find
 in the following locations:

    * gef (https://github.com/hugsy/gef) in /opt/gef/
    * pwndbg (https://github.com/pwndbg/pwndbg) in /opt/pwndbg/
    * gdbinit (https://github.com/gdbinit/Gdbinit) in /opt/gdbinit/
    * pwntools (https://github.com/Gallopsled/pwntools)
    * radare2 (http://www.radare.org/)

--[ More information ]--

  For more information regarding individual wargames, visit
  http://www.overthewire.org/wargames/

  For support, questions or comments, contact us on discord or IRC.

  Enjoy your stay!

bandit0@bandit:~$
```

NOTA: A la web https://overthewire.org/wargames/bandit/ hi ha alguns reptes de hacking per iniciar-se. Aquest que indiquem, és el primer nivell.

Política PERMISSIVA al Firewall: blocar el que no volem

ATENCIÓ:

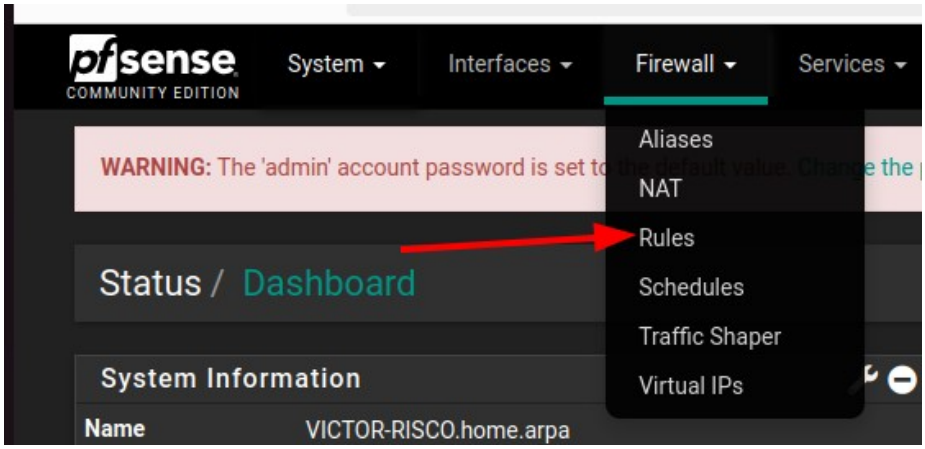
Quan feu les proves, recordeu buidar **TOT** l'historial del navegador web i tancar-ho i tornar-ho a obrir.

- Els navegadors web tenen una memòria cau (caché) que fan que sembli que encara funciona l'accés a una pàgina que s'acaba de blocar.
- També mantenen la connexió a una pàgina si s'ha acabat d'accedir, i el firewall manté la connexió encara que s'hagi blocat.
- Alternativament, podeu fer servir l'eina curl per a les peticions Web, que no té caché.

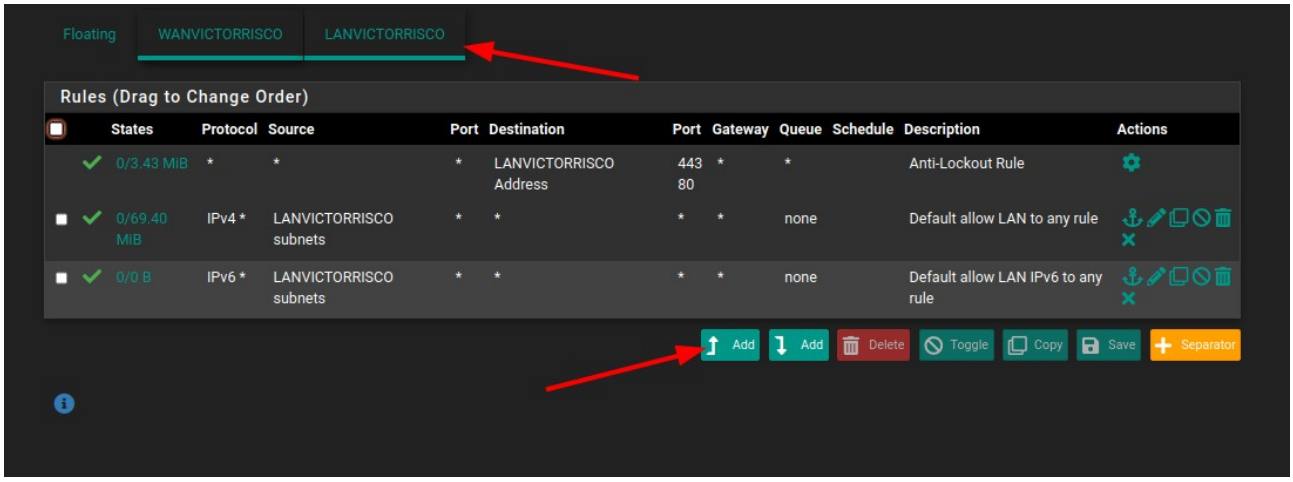
També hi ha una caché del client DNS, per no tornar a resoldre un domini que fa poc ja s'ha resolt.

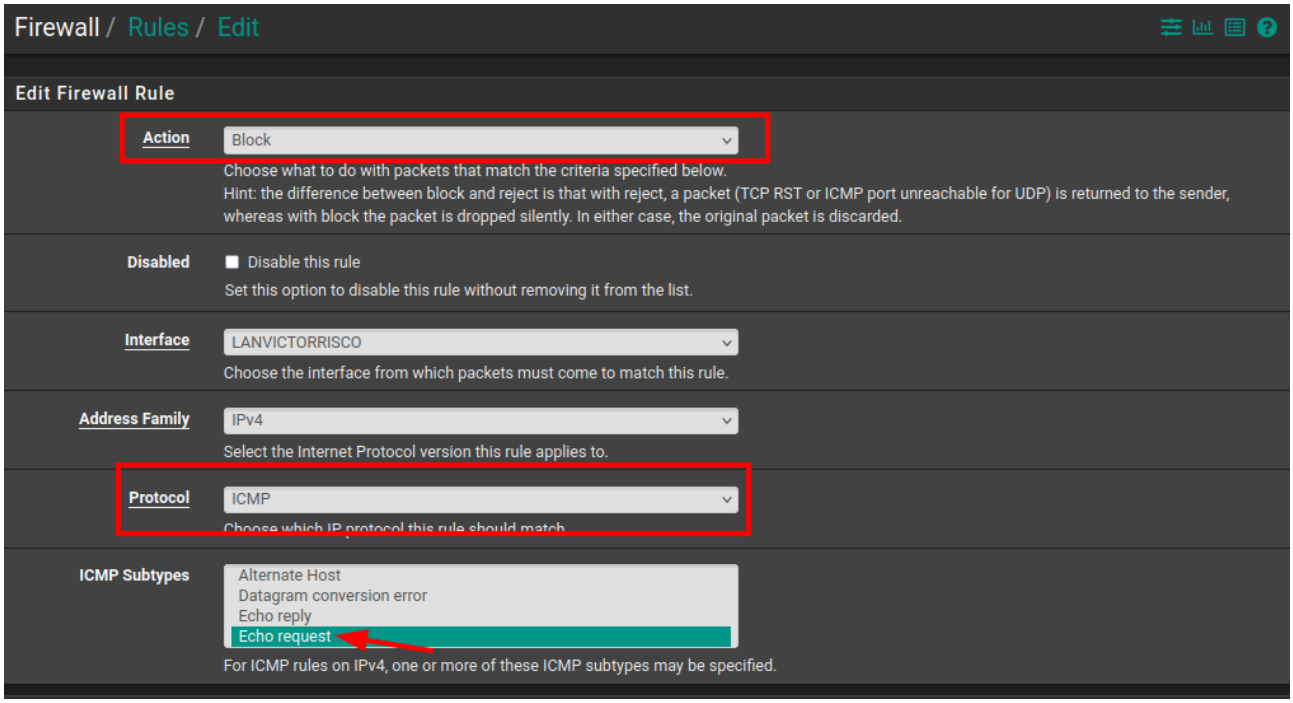
- En aquest cas, encara que bloquem la resolució DNS, el client encara sabrà la resolució per que la te en caché.
- Podem buidar la caché DNS del client a Ubuntu fent: "resolvectl flush-caches" i ens assegurem de que es fa la petició de veritat.

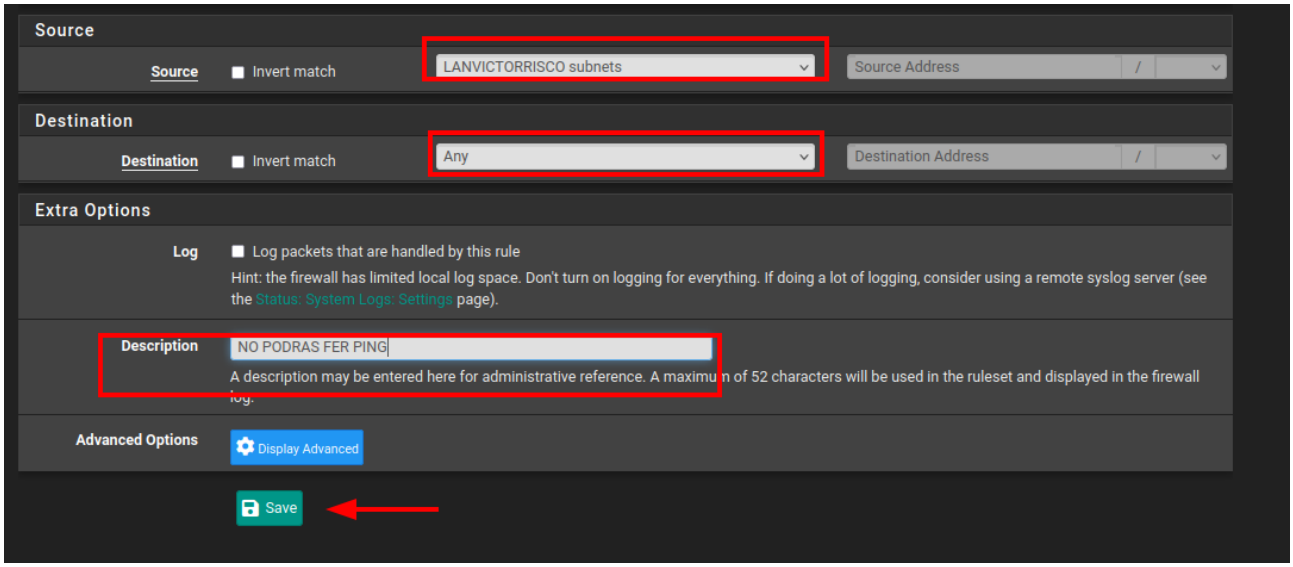
9- Apliquem la política oberta (tot permés, apliquem restriccions). Posarem restriccions de certs protocols. Bloca els ICMP de la xarxa LAN interna. Això es fa a "Firewall→Rules".

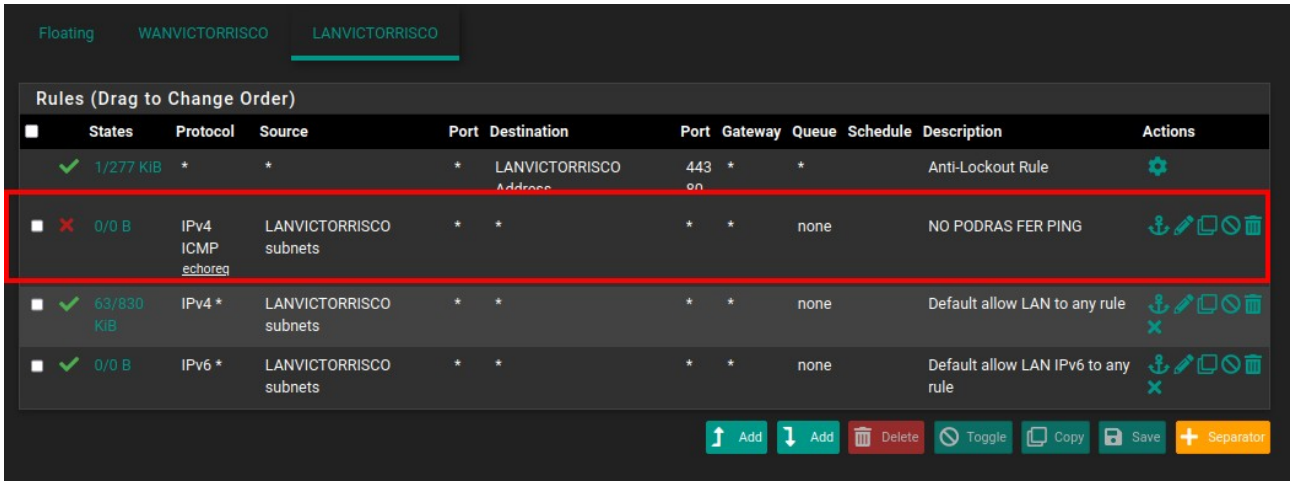


- A la pestanya LAN (interfície LAN pel pfsense), afegirem una regla nova que bloqui el protocol ICMP: origen "LAN Net", que és qualsevol adreça de la xarxa LAN i destí qualsevol.

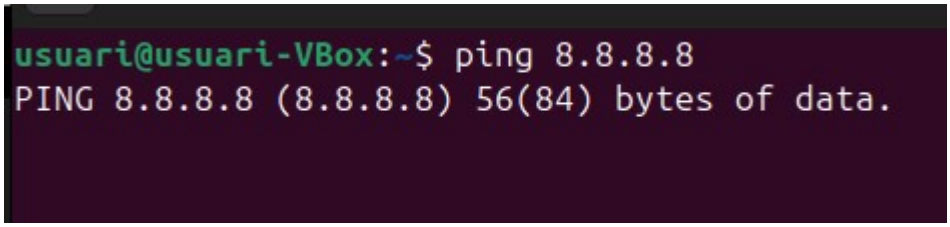






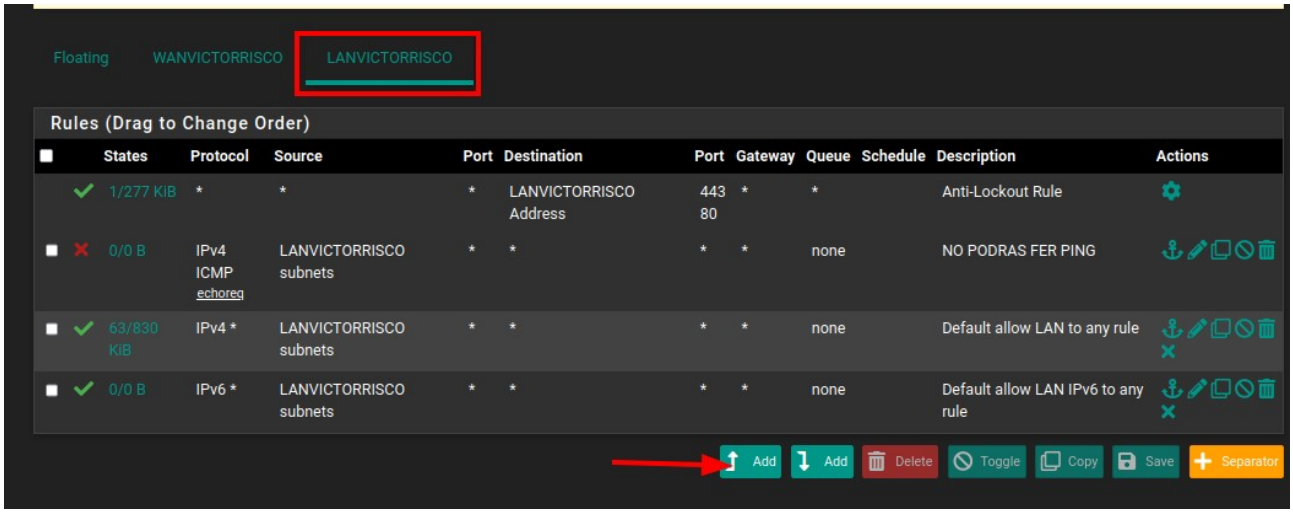


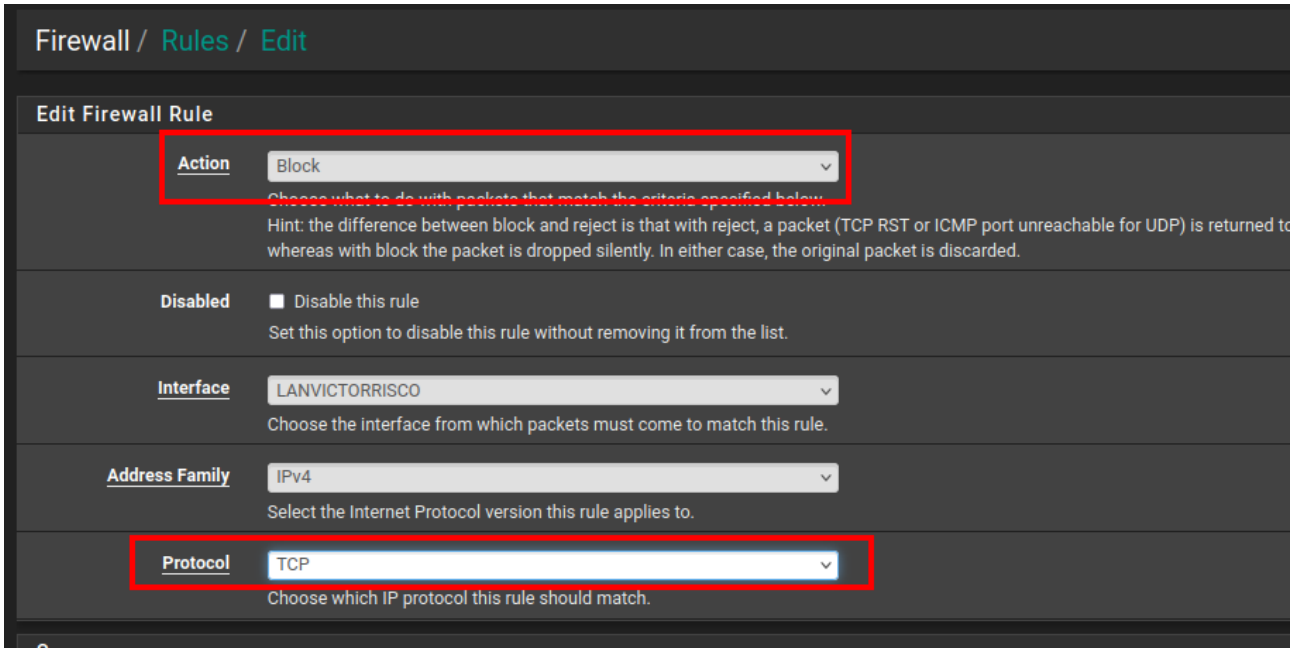
- Comprova que no pots fer ping a 8.8.8.8 (ni cap màquina pública).

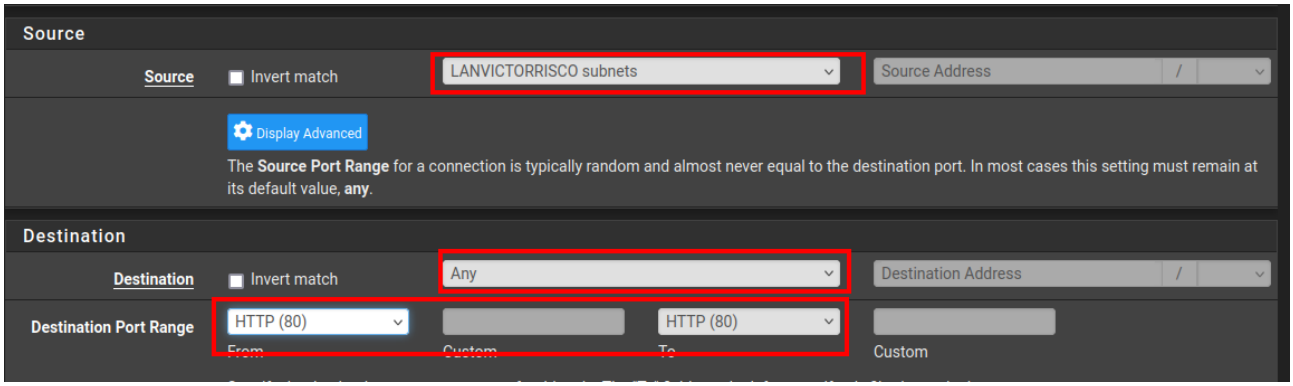


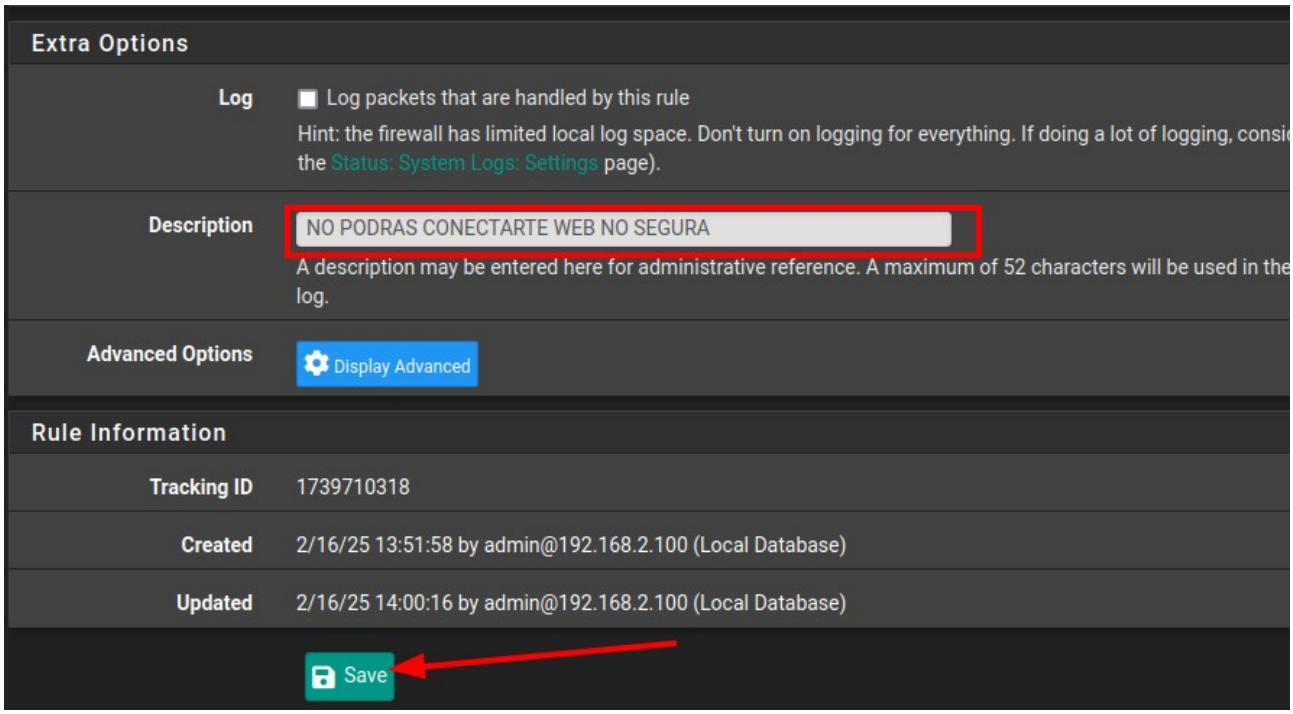
- Bloca ara el servei web segur i no segur. Són dues regles, una per a cada port (origen LAN Net, destinació qualsevol, port destí 80 http, port destí 443 https). Comprova que no pots navegar per pàgines web. Però si pots fer servir ssh i la resta de serveis.

PORT 80

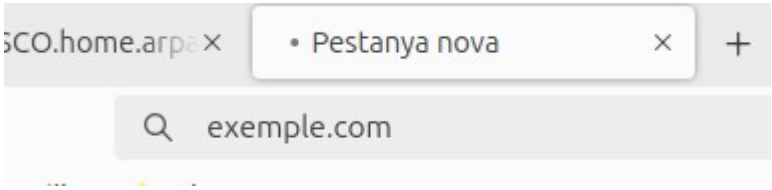

Floating
WANVICTORRISCO
LANVICTORRISCO
Rules (Drag to Change Order)
States Protocol Source Port Destination Port Gateway Queue Schedule Description Actions
1/277 KiB * * * LANVICTORRISCO Address 443 80 * * Anti-Lockout Rule
0/0 B IPv4 ICMP echoreq LANVICTORRISCO subnets * * * * none NO PODRAS FER PING
63/830 KiB IPv4 * LANVICTORRISCO subnets * * * * none Default allow LAN to any rule
0/0 B IPv6 * LANVICTORRISCO subnets * * * * none Default allow LAN IPv6 to any rule
Add
Add
Delete
Toggle
Copy
Save
Separator


Firewall / Rules / Edit
Edit Firewall Rule
Action
Block
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to
whereas with block the packet is dropped silently. In either case, the original packet is discarded.
Disabled
Disable this rule
Set this option to disable this rule without removing it from the list.
Interface
LANVICTORRISCO
Choose the interface from which packets must come to match this rule.
Address Family
IPv4
Select the Internet Protocol version this rule applies to.
Protocol
TCP
Choose which IP protocol this rule should match.

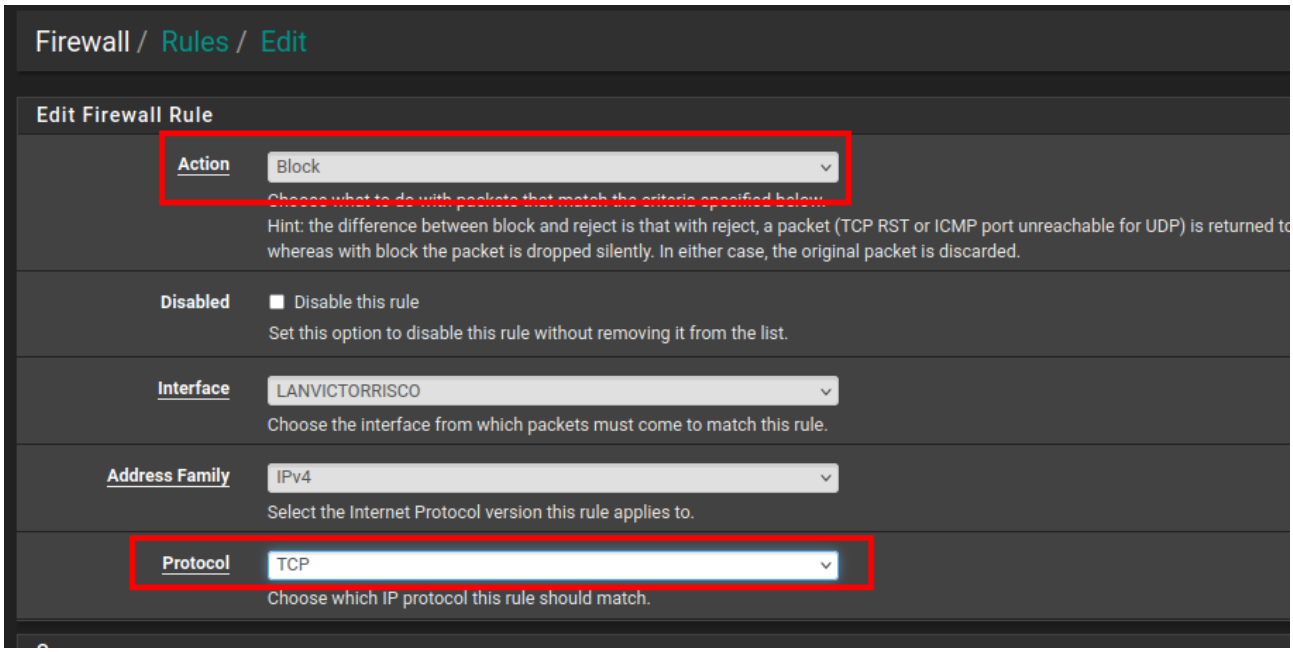

Source
Source
Invert match
LANVICTORRISCO subnets
Source Address
Display Advanced
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.
Destination
Destination
Invert match
Any
Destination Address
Destination Port Range
HTTP (80)
HTTP (80)
Custom

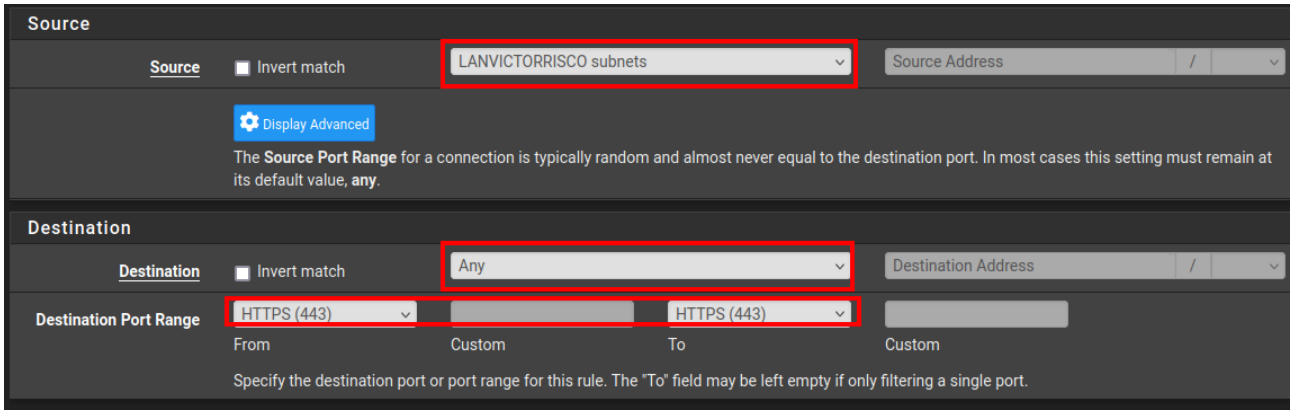


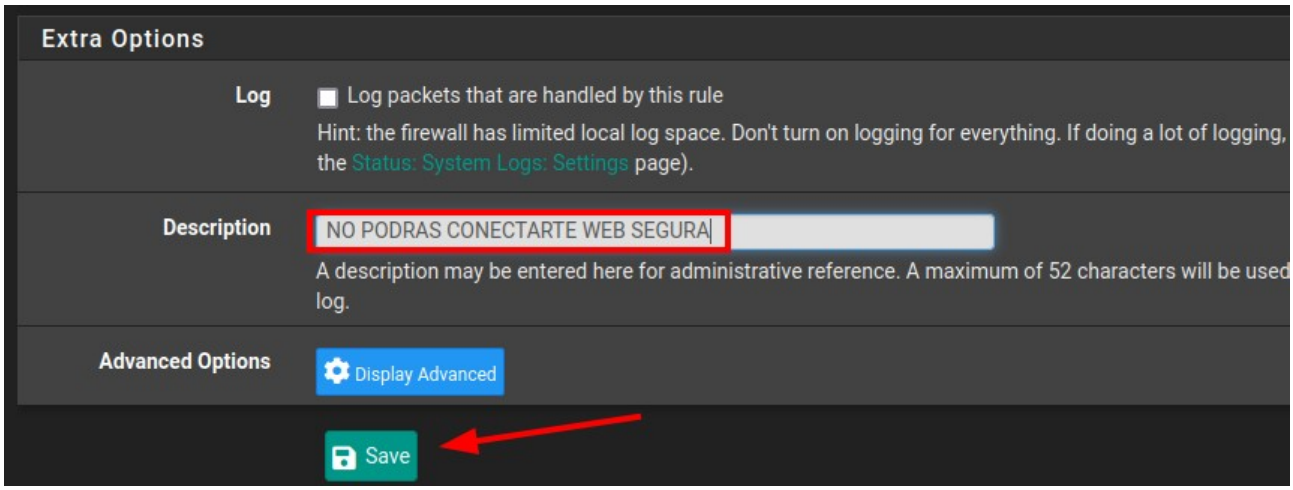
ES QUEDA COM PENSANT TOT EL RATO SENSE ARRIBAR A CAP LLOC



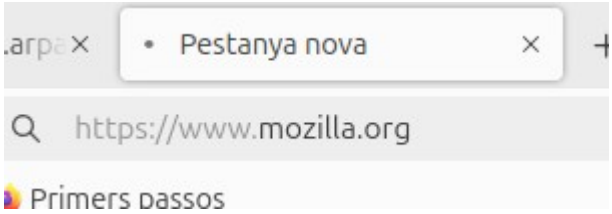
PORT 443





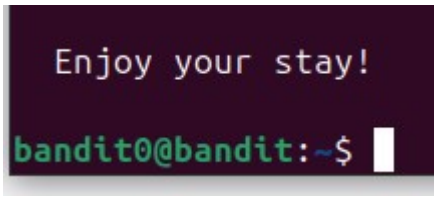


ES QUEDA COM PENSANT TOT EL RATO SENSE ARRIBAR A CAP LLOC



Però si pots fer servir ssh i la resta de serveis.





FTP

```
usuari@usuari-VBox:~$ ftp ftp.rediris.es
Trying 130.206.13.2:21 ...
Connected to ftp.rediris.es.
220-  Bienvenido al servicio de replicas de RedIRIS.
220-     Welcome to the RedIRIS mirror service.
220 Only anonymous FTP is allowed here
Name (ftp.rediris.es:usuari): anonymous
230-            RedIRIS - Red Académica y de Investigación Española
230-                RedIRIS - Spanish National Research Network
230-
230-           ftp://ftp.rediris.es  -=-  http://ftp.rediris.es
230 Anonymous user logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

- Canvia les regles anteriors per posar Reject en lloc de Block. Quina diferència trobes entre les respostes a Reject i Block quan intentes navegar per la web? Explica-ho. Per un atacant, quina és pitjor? Per què?

Resum:

- Block: Quan el tallafoc utilitza Block, el client no rep cap resposta, així que es queda esperant sense saber si el servidor existeix o si el tràfic està simplement bloquejat. Això fa que sigui difícil per un atacant saber si existeix un servidor o no.

- Reject: Quan utilitza Reject el tallafoc respon i diu que la connexió ha estat rebutjada. Això dona més informació a l'atacant, ja que sap que existeix un servidor .

Diferència en l'ús:

- Amb Block el navegador es queda esperant o acaba fallant després d'un temps.

- Amb Reject el navegador rep una resposta immediata que li diu que la connexió ha estat rebutjada.

Per un atacant, què és pitjor?

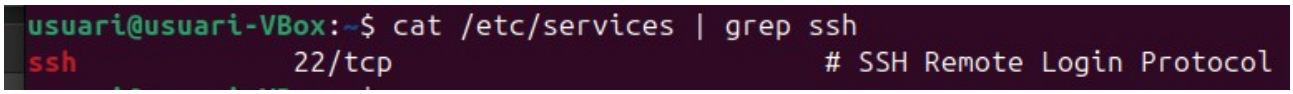
Block és pitjor per a l'atacant perquè no rep cap resposta immediata, així que no sap si el servidor existeix o no. Això fa que perdi temps intentant atacar un servidor que potser ni existeix. En canvi, amb Reject l'atacant sap que el servidor està actiu, i pot continuar buscant altres vulnerabilitats més ràpidament.

SI POSO REJECT APAREIX AIXO:



NOTA: Pot aparèixer una campana a la barra superior del Pfsense indicant que hi ha avisos. Si veiem que algun d'ells parla de que no es pot assignar memòria, aneu a "System > Advanced > Firewall & NAT > Firewall Maximum Table Entries". Veureu el valor per defecte de 200.000 entrades. Poseu 300.000 i apliqueu els canvis. S'hauria de solucionar.

Asi sabes si es TCP o UDP



FITA 3: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.

4. Política RESTRICTIVA al Firewall, permetre el que volem

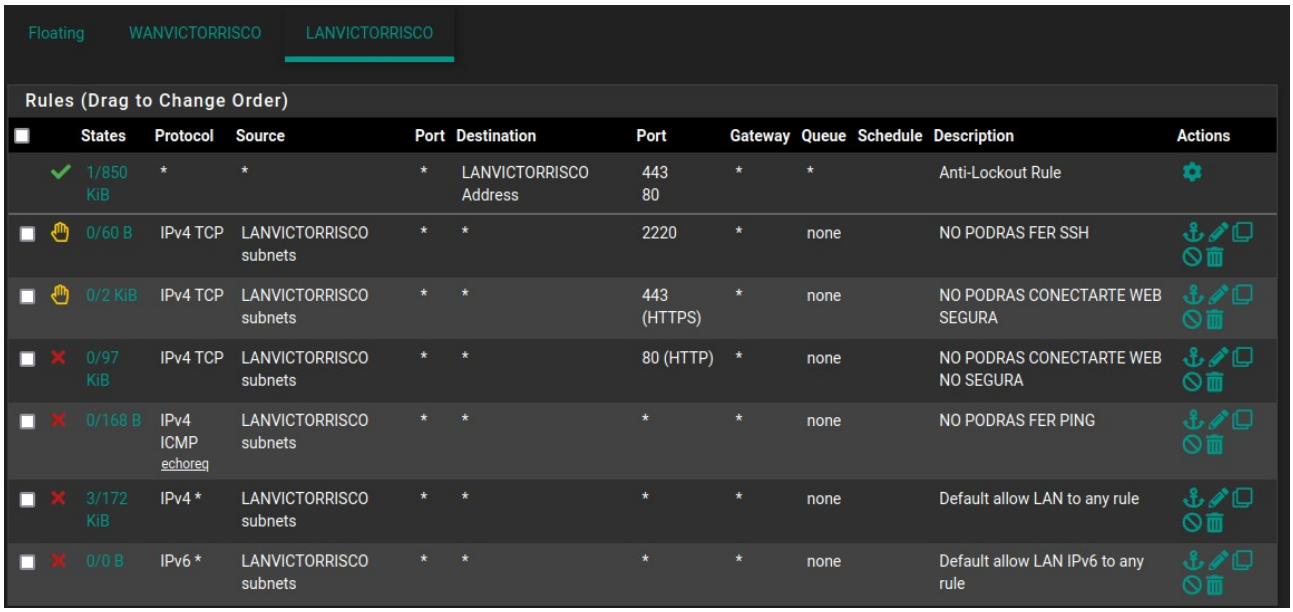
10- Ara mirarem de blocar tot el tràfic de la xarxa interna cap a internet, per configurar una política restrictiva (tot tancat, obrim excepcions).

PER VEURE SI RESOL EL DNS

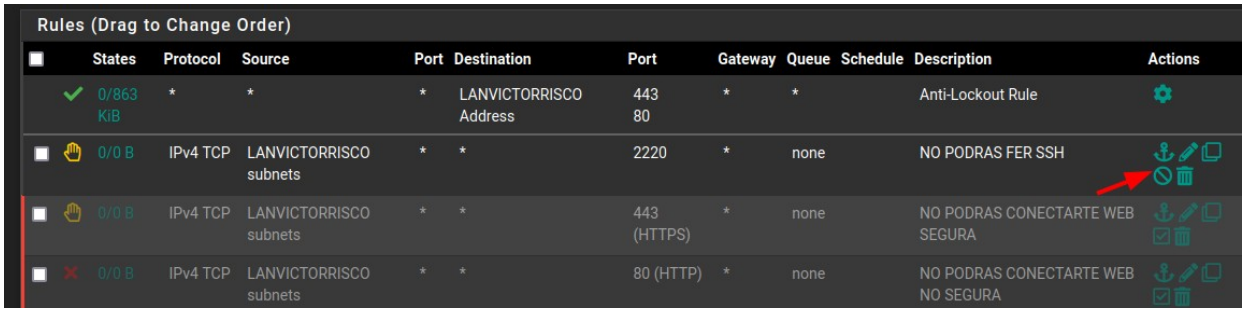
```
usuari@usuari-VBox:~$ resolvectl
Global
         Protocols: -LLMNR -mDNS -DNSOverTLS DNSSEC=no/unsupported
  resolv.conf mode: stub

Link 2 (enp0s3)
    Current Scopes: DNS
         Protocols: +DefaultRoute -LLMNR -mDNS -DNSOverTLS DNSSEC=no/unsupported
Current DNS Server: 208.67.222.222
       DNS Servers: 208.67.222.222
```

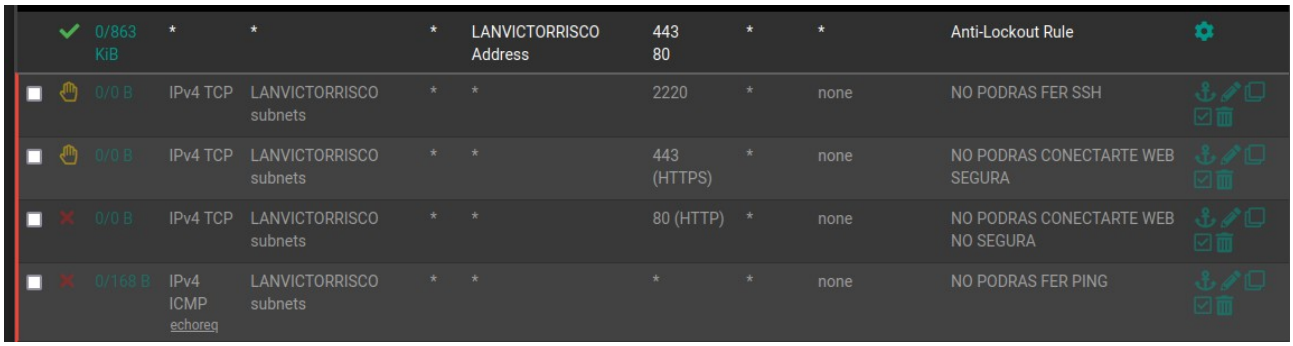
- Desactiva (sense eliminar) totes les regles de la interfície LAN. Pfsense sempre treballa en mode restrictiu, i per tant l'última regla, que s'ha d'assumir, és blocar tot.



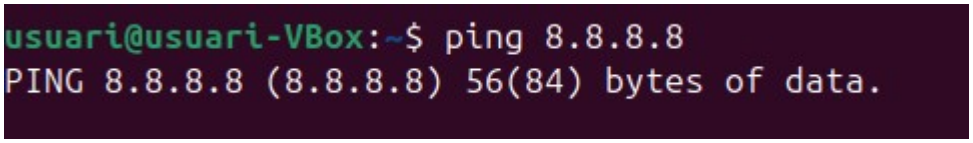
- Pots desactivar les regles que havíem posat abans picant a sobre la icona de desactivar a la dreta de la regla.

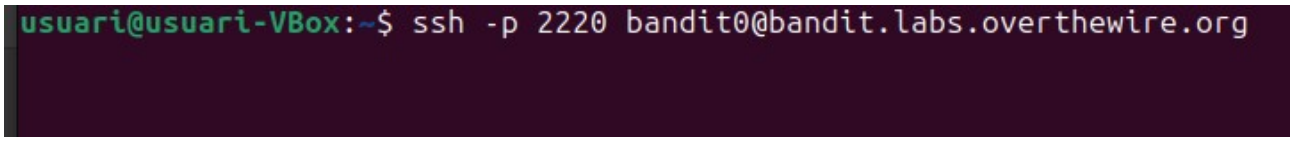


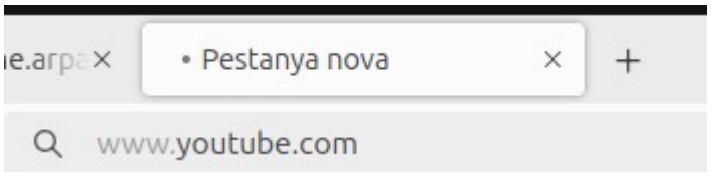
- Les regles es tornen grises quan es desactiven.



- També les pots esborrar si estàs segur que no les necessites més. Comprovem de nou els serveis i ens assegurem que no funcionen.

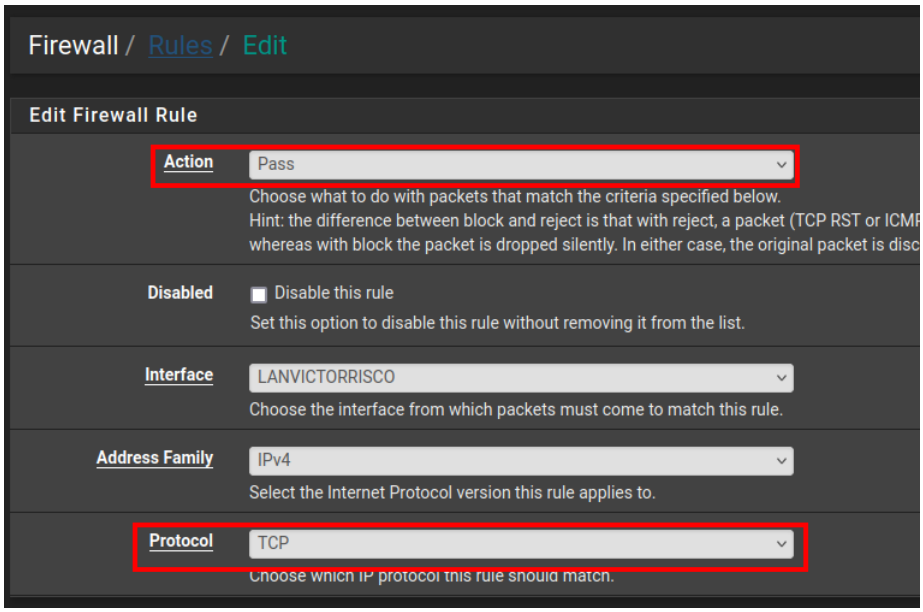


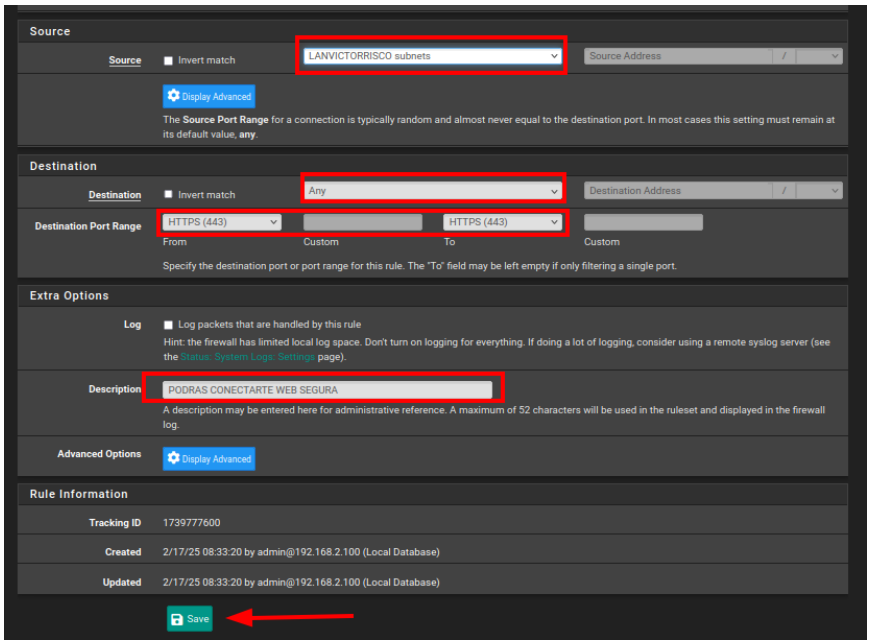




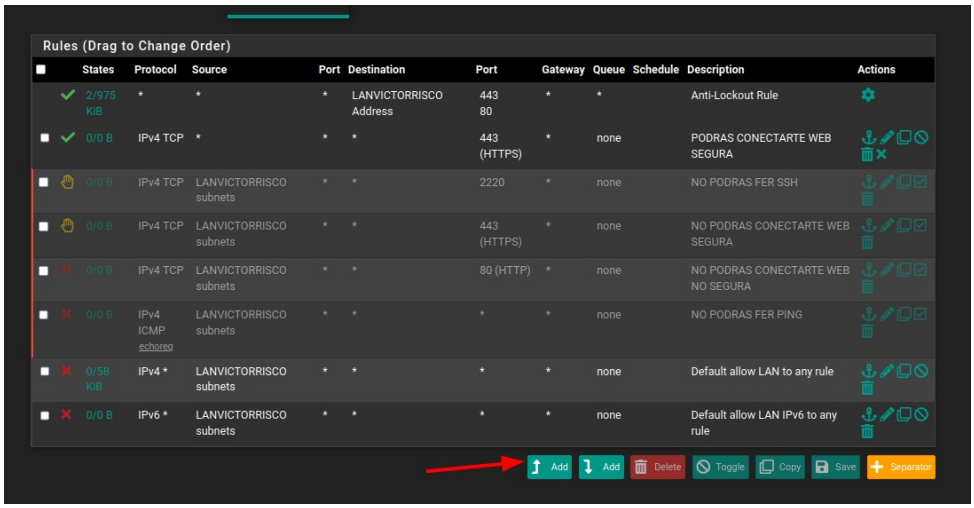
11- Obrirem l'accés de la xarxa interna cap a serveis web i web segura.

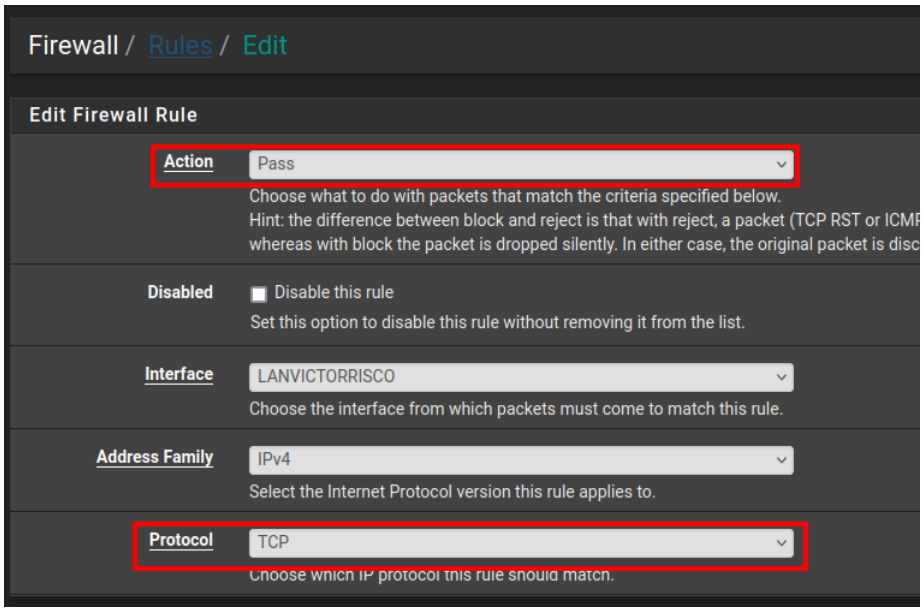
serveis web segura:

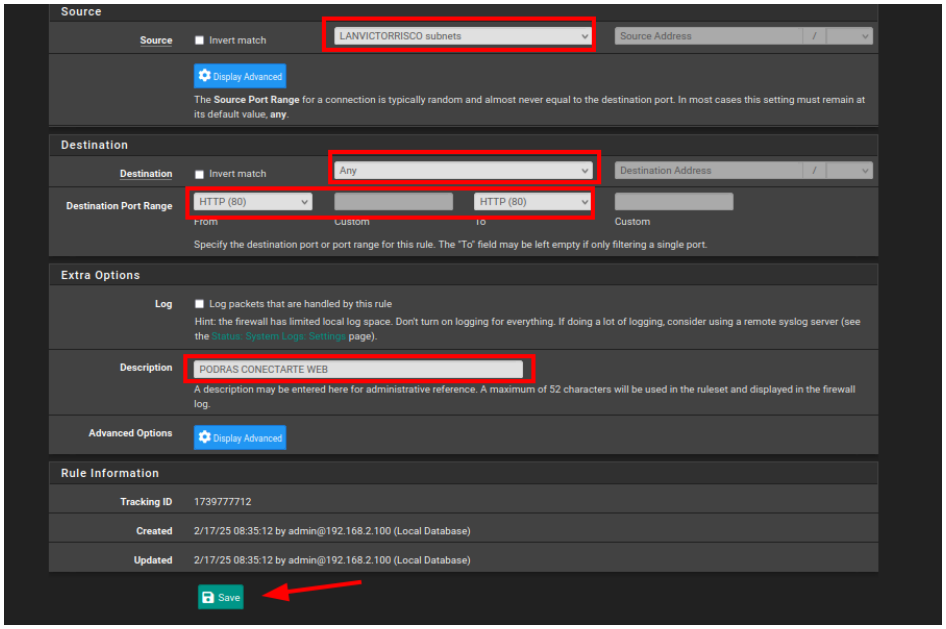

Firewall / Rules / Edit
Edit Firewall Rule
Action
Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP
whereas with block the packet is dropped silently. In either case, the original packet is disc
Disabled
Disable this rule
Set this option to disable this rule without removing it from the list.
Interface
LANVICTORRISCO
Choose the interface from which packets must come to match this rule.
Address Family
IPv4
Select the Internet Protocol version this rule applies to.
Protocol
TCP
Choose which IP protocol this rule should match.

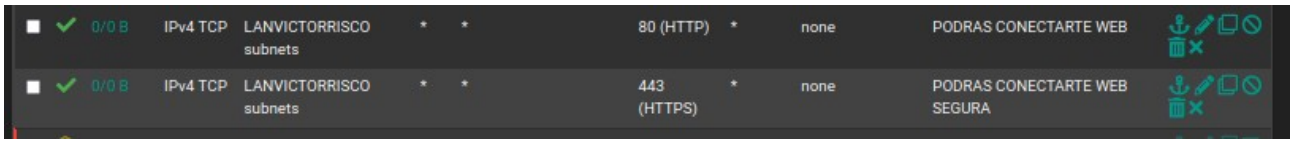

Source
Source
Invert match
LANVICTORRISCO subnets
Source Address
Display Advanced
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.
Destination
Destination
Invert match
Any
Destination Address
Destination Port Range
HTTPS (443)
From
Custom
HTTPS (443)
To
Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.
Extra Options
Log
Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).
Description
PODRAS CONECTARTE WEB SEGURA
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.
Advanced Options
Display Advanced
Rule Information
Tracking ID
1739777600
Created
2/17/25 08:33:20 by admin@192.168.2.100 (Local Database)
Updated
2/17/25 08:33:20 by admin@192.168.2.100 (Local Database)
Save

serveis web:

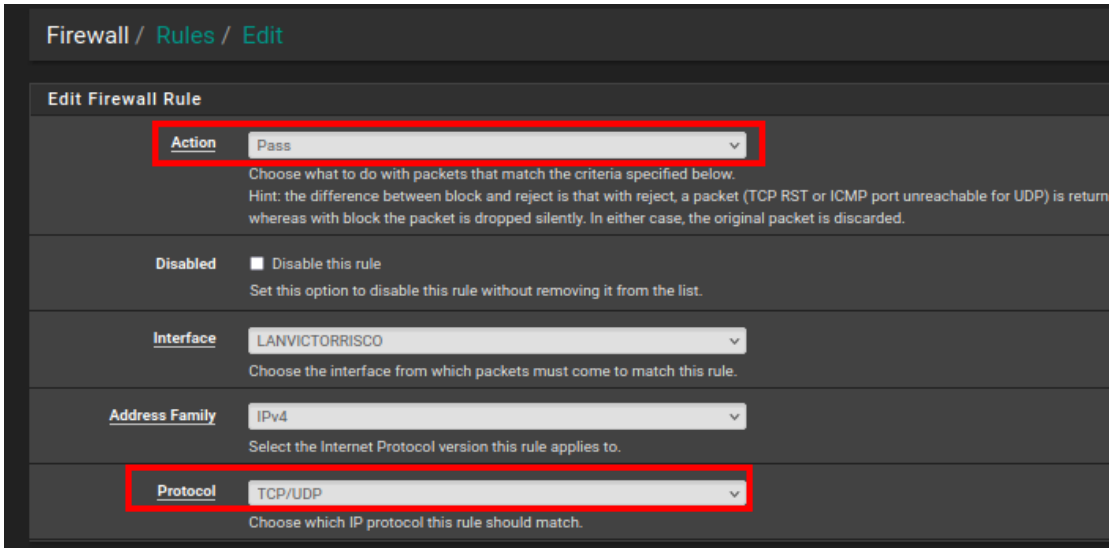

Rules (Drag to Change Order)
States Protocol Source Port Destination Port Gateway Queue Schedule Description Actions
2/975 KiB * * * LANVICTORRISCO Address 443 80 * * Anti-Lockout Rule
0/0 B IPv4 TCP * * * 443 (HTTPS) * none PODRAS CONECTARTE WEB SEGURA
0/0 B IPv4 TCP LANVICTORRISCO subnets * * 2220 * none NO PODRAS FER SSH
0/0 B IPv4 TCP LANVICTORRISCO subnets * * 443 (HTTPS) * none NO PODRAS CONECTARTE WEB SEGURA
0/0 B IPv4 TCP LANVICTORRISCO subnets * * 80 (HTTP) * none NO PODRAS CONECTARTE WEB NO SEGURA
0/0 B IPv4 ICMP echoreq LANVICTORRISCO subnets * * * * none NO PODRAS FER PING
0/58 KiB IPv4 * LANVICTORRISCO subnets * * * * none Default allow LAN to any rule
0/0 B IPv6 * LANVICTORRISCO subnets * * * * none Default allow LAN IPv6 to any rule
Add Add Delete Toggle Copy Save Separator

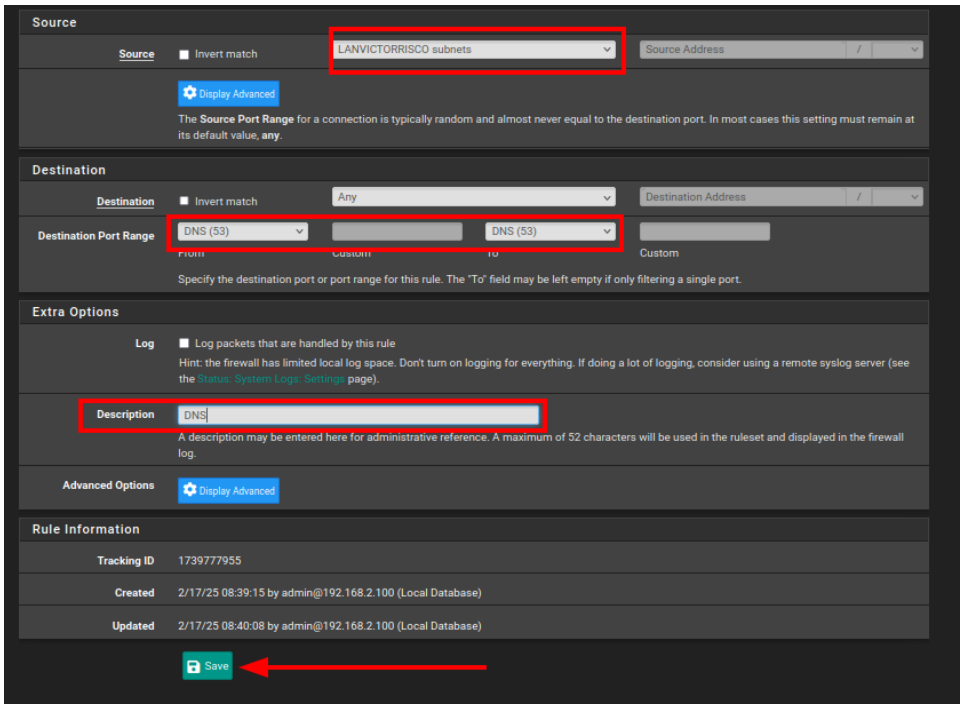

Firewall / Rules / Edit
Edit Firewall Rule
Action
Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP
whereas with block the packet is dropped silently. In either case, the original packet is disc
Disabled
Disable this rule
Set this option to disable this rule without removing it from the list.
Interface
LANVICTORRISCO
Choose the interface from which packets must come to match this rule.
Address Family
IPv4
Select the Internet Protocol version this rule applies to.
Protocol
TCP
Choose which IP protocol this rule should match.

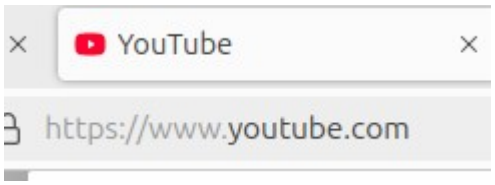

Source
Source
Invert match
LANVICTORRISCO subnets
Source Address
Display Advanced
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.
Destination
Destination
Invert match
Any
Destination Address
Destination Port Range
HTTP (80)
From
Custom
HTTP (80)
To
Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.
Extra Options
Log
Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).
Description
PODRAS CONECTARTE WEB
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.
Advanced Options
Display Advanced
Rule Information
Tracking ID
1739777712
Created
2/17/25 08:35:12 by admin@192.168.2.100 (Local Database)
Updated
2/17/25 08:35:12 by admin@192.168.2.100 (Local Database)
Save



- Comprovem que es pot accedir a serveis web. Recorda que s'ha de poder resoldre el nom de domini (DNS, port 53 TCP i UDP)…







- Prova ftp i ssh. (La resta de protocols continuarà sense funcionar).

PING

```
usuari@usuari-VBox:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
```

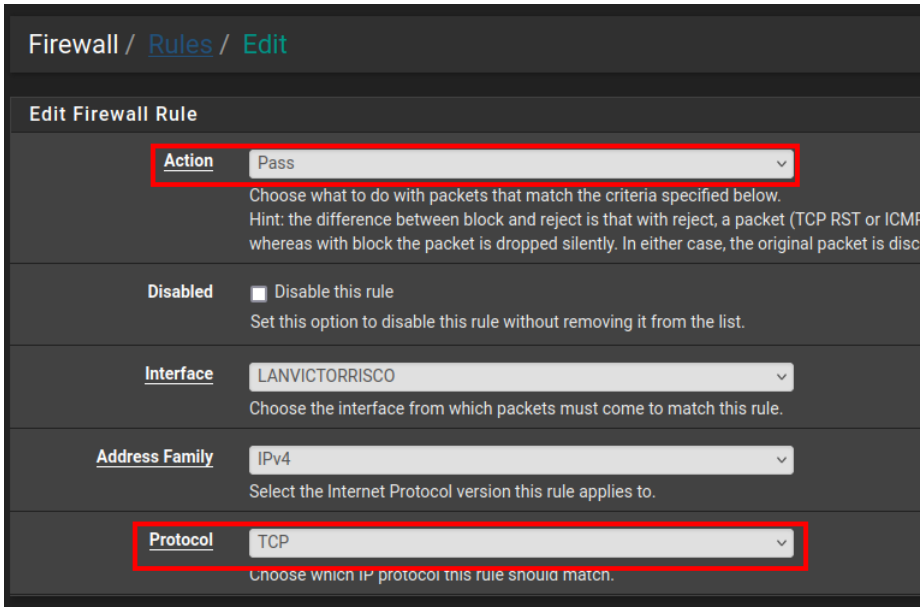
SSH

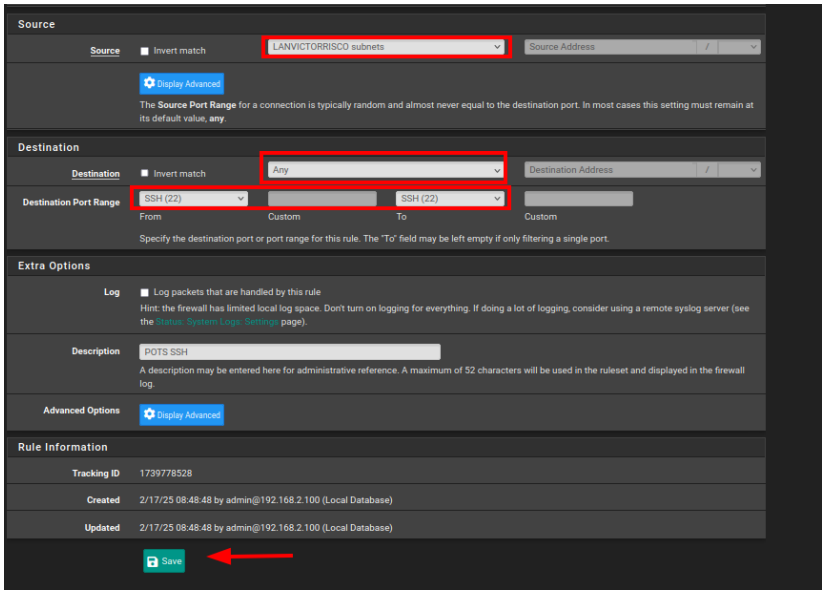
```
usuari@usuari-VBox:~$ ssh -p 2220 bandit0@bandit.labs.overthewire.org
```

FTP

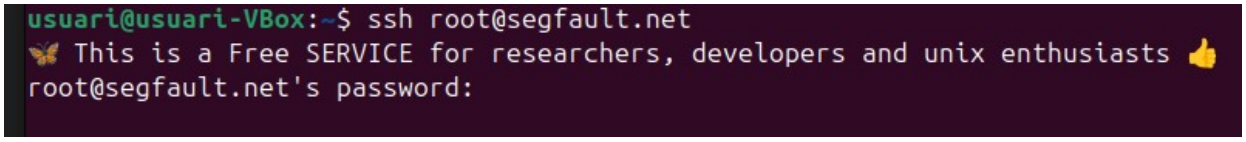
```
usuari@usuari-VBox:~$ ftp ftp.rediris.es
Trying 130.206.13.2:21 ...
```

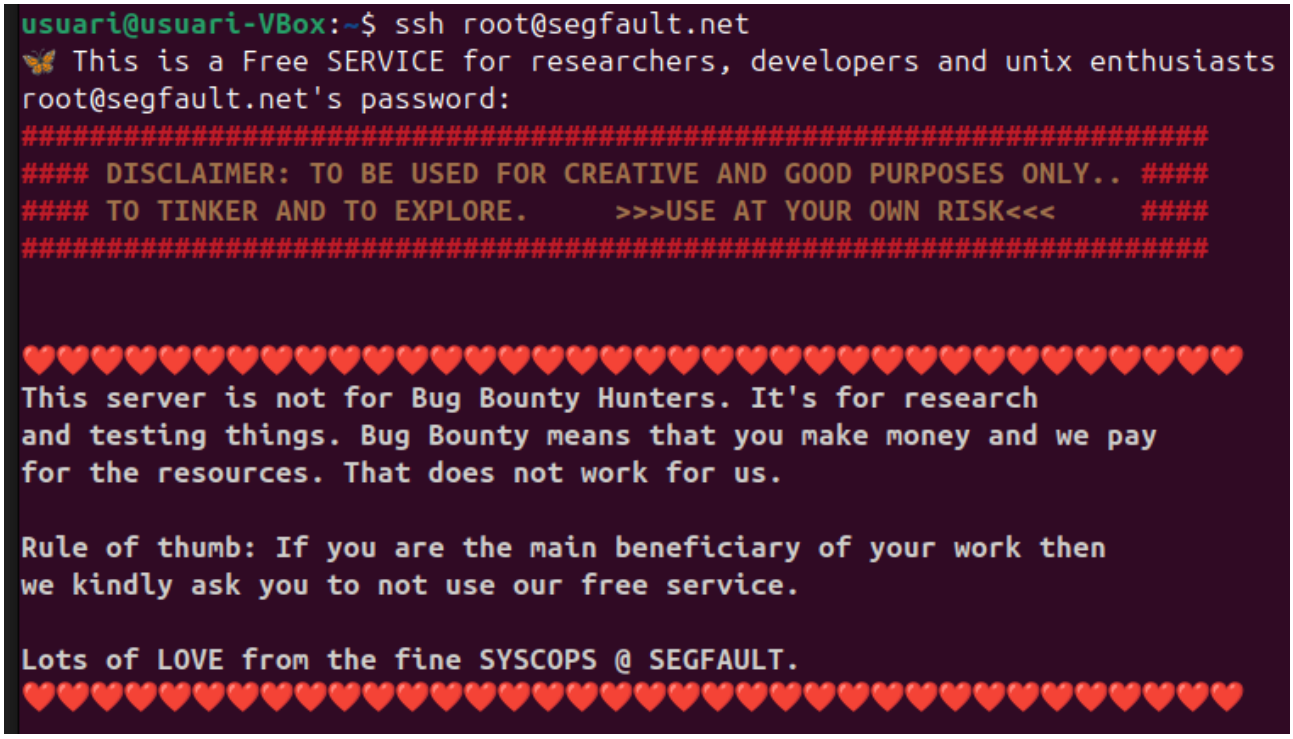
12-Obrirem l'accés a ssh. Recorda posar-la abans de la que bloca tots els protocols.



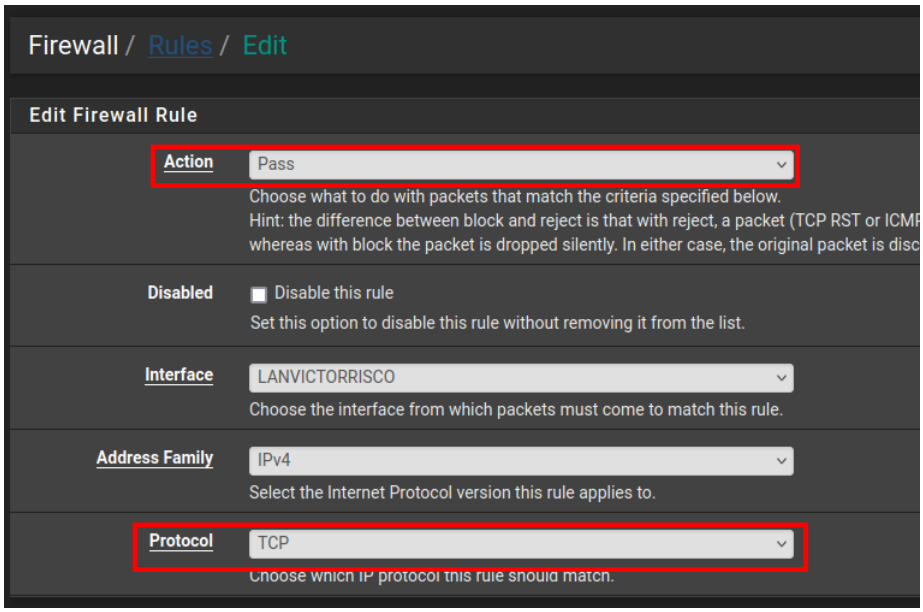


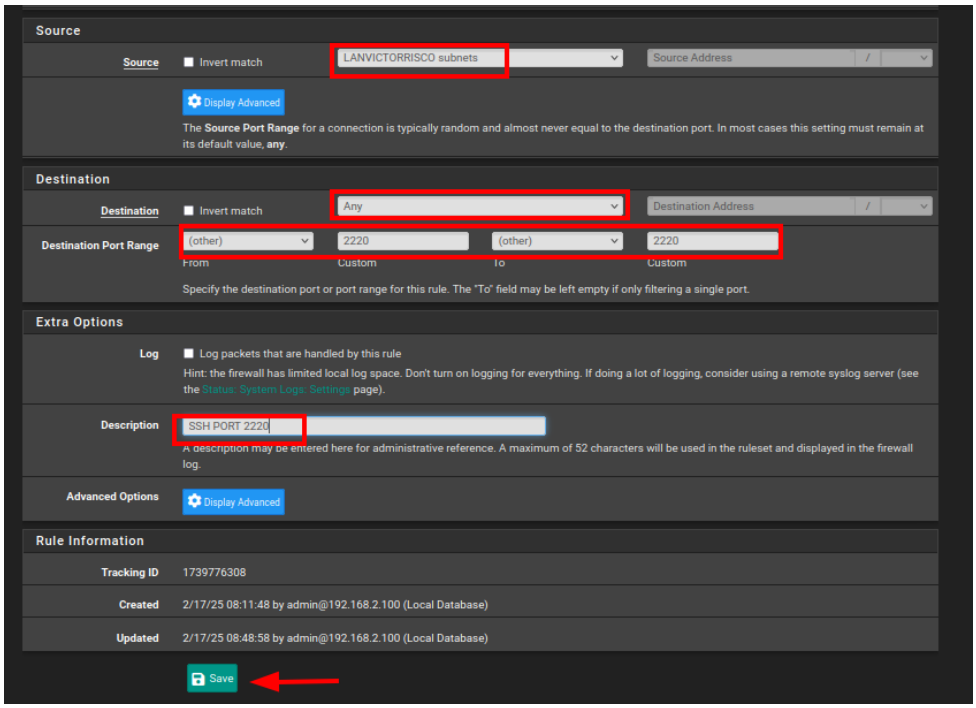
- Prova el servei SSH https://www.thc.org/segfault/ que ofereix un servidor ssh a Internet, on seràs root. Mira com cal connectar i comprova que funciona.





- Prova també el servei bandit.labs.overthewire.org. Recorda que connecta pel port 2220 i que cal obrir-ho. El nom d'usuari és "bandit0" i el password és bandit0.


Firewall / Rules / Edit
Edit Firewall Rule
Action
Pass
Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP
whereas with block the packet is dropped silently. In either case, the original packet is disc
Disabled
Disable this rule
Set this option to disable this rule without removing it from the list.
Interface
LANVICTORRISCO
Choose the interface from which packets must come to match this rule.
Address Family
IPv4
Select the Internet Protocol version this rule applies to.
Protocol
TCP
Choose which IP protocol this rule should match.


Source
Source
Invert match
LANVICTORRISCO subnets
Source Address
Display Advanced
The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.
Destination
Destination
Invert match
Any
Destination Address
Destination Port Range
(other)
2220
(other)
2220
From
Custom
To
Custom
Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.
Extra Options
Log
Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).
Description
SSH PORT 2220
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.
Advanced Options
Display Advanced
Rule Information
Tracking ID
1739776308
Created
2/17/25 08:11:48 by admin@192.168.2.100 (Local Database)
Updated
2/17/25 08:48:58 by admin@192.168.2.100 (Local Database)
Save



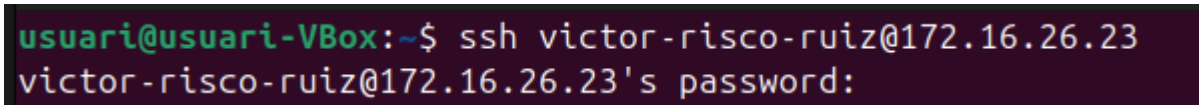


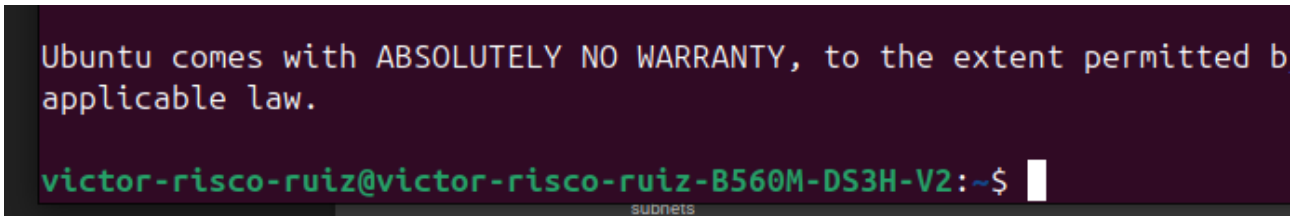
- Instal·la ssh a la teva màquina física i connectat amb ssh des del client virtual.

MAQUINA MEVA

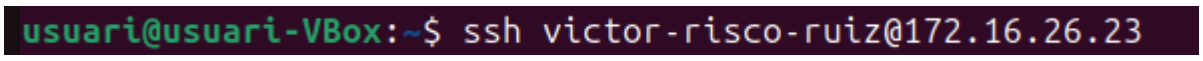


MAQUINA VIRTUAL





13- Comprova amb Wireshark, des de la màquina física quines IP's són les que realment fan la petició ssh.



- Hauria de ser la IP de la interfície WAN del nostre Pfsense?



- o la del nostre client Ubuntu?



FITA 4: Demana al professor que validi aquesta part anterior de la pràctica quan l'hagis acabat.